PADRÕES E NORMAS E POLÍTICA DE SEGURANÇA DA INFORMAÇÃO

Sumário

PADRÕES E NORMAS E POLÍTICA DE SEGURANÇA DA INFORMAÇÃO 1

NOSSA HISTÓRIA 4

1. INTRODUÇÃO 5

2. SEGURANÇA DA INFORMAÇÃO.....6

2.1 Princípios básicos da segurança da informação.....8

2.2 Ameaças.....10

2.3 Ataques.....10

3. CONTROLE DE SEGURANÇA.....14

3.1 Processo de Autenticação 14

4. INCIDENTE DE SEGURANÇA E USO ABUSIVO NA REDE.....15

4.1 Registros de Eventos (logs) 15

5. ESTUDOS DAS NORMAS ISO 27000 – APLICAÇÃO DE NORMAS, PADRÕES INTERNACIONAIS E CERTIFICAÇÃO 15

5.1 Objetivos e funções - ISO/IEC 27000.....16

5.1.1 Critérios para certificação 17

6. RELACIONAMENTO ENTRE AS NORMNAS DA SÉRIE ISO/IEC 27000 19

6.1 Benefícios da Aplicação da Norma ISO/IEC 27000 e sua série.....22

7. DIFICULDADES PARA IMPLANTAÇÃO DE UM SGSI 23

Principais melhorias nas organizações com a implantação de um SGSI 24

8. ESTUDO DAS NORMAS ISO 27005 e ISO 31000 – APLICAÇÕES DE NORMAS E PADRÕES INTERNACIONAIS 25

8.1 Conceitos associados.....26

9. PRINCÍPIOS DA GESTÃO.....30

9.1 Normas ISO / IEC 27005 32

9.2 ISO 31000 - Princípios da Gestão de Riscos, princípios e diretrizes 33

9.3 Objetivos e aplicações da gestão de riscos e das normas ISO/IEC 27005 e ISO 31000 34

9.4 Estudo da norma ISO 22301 - Aplicação de normas e padrões internacionais 39

10. CRIPTOGRAFIA, CERTIFICAÇÕES DIGITAIS, ASSINATURA DIGITAL 40

10.1 Criptografia 41

10.2 Tipos combinados de chaves 46

10.3 Ataques e segurança 46

11. ASSINATURAS DIGITAIS 48

11.1 Certificação digital 50

11.1 Segurança em Sistemas da Informação 51

12. MODELOS E MECANISMOS DE SEGURANÇA DOS SISTEMAS DE INFORMAÇÃO 58

12.1 Metodologia para garantir a segurança nos sistemas de informação 59

12.2 Mecanismos de segurança da informação 60

13. REFERÊNCIAS: 64

NOSSA HISTÓRIA

A nossa história inicia com a realização do sonho de um grupo de empresários, em atender à crescente demanda de alunos para cursos de Graduação e Pós-Graduação. Com isso foi criado a nossa instituição, como entidade oferecendo serviços educacionais em nível superior.

A instituição tem por objetivo formar diplomados nas diferentes áreas de conhecimento, aptos para a inserção em setores profissionais e para a participação no desenvolvimento da sociedade brasileira, e colaborar na sua formação contínua. Além de promover a divulgação de conhecimentos culturais, científicos e técnicos que constituem patrimônio da humanidade e comunicar o saber através do ensino, de publicação ou outras normas de comunicação.

A nossa missão é oferecer qualidade em conhecimento e cultura de forma confiável e eficiente para que o aluno tenha oportunidade de construir uma base profissional e ética. Dessa forma, conquistando o espaço de uma das instituições modelo no país na oferta de cursos, primando sempre pela inovação tecnológica, excelência no atendimento e valor do serviço oferecido.

1. INTRODUÇÃO

As Organizações têm se tornado mais rápidas e eficientes na troca de informações e tomadas de decisões estratégicas. Isto se deve, em grande parte, a evolução da Tecnologia da Informação.

Porém, este novo ambiente tornou-se mais complexo, heterogêneo e distribuído, dificultando a gestão de questões relativas à segurança da informação. As ameaças aos ambientes computacionais, tanto físicos quanto lógicos, passam por uma grande evolução, tanto em quantidade de equipamentos e bytes transmitidos quanto em formato. Portanto, novos vírus e formas de ataque, internos e externos, surgem a cada dia, trazendo riscos às informações das empresas e/ou de parceiros que estas representem. Sendo assim, as estatísticas mostram que as fraudes em Informática são problemas constantes em escala mundial, exigindo o investimento de muitos recursos financeiros das organizações.

A evolução é parte inquestionável da vida e o homem é o maior resultado disto. No campo da TI (tecnologia da informação), a maior evolução é a Internet. Desde o seu aparecimento, ocorreram mudanças de paradigmas o que permitiu a expansão da conectividade e acessibilidade. Isto influenciou drasticamente como as empresas administram seus negócios.

Segundo Sêmola (2003), “os computadores tomam conta dos ambientes de escritório, quebram o paradigma e acesso local à informação, e chegam a qualquer lugar do mundo através dos cada vez mais portáteis notebooks e da rede mundial de computadores: a Internet.” (SÊMOLA, 2003, p.3).

Em função disto, a segurança da informação teve que evoluir e saiu do nível técnico, reservado à TI, onde a única preocupação era ter um bom antivírus, um firewall bem configurado. Com a evolução, houve a necessidade de se pensar também no nível da gestão, investindo e desenvolvendo os processos e as pessoas. Os aspectos relativos à implantação de uma eficiente Política de Segurança de Informação se encontram em uma crescente nos últimos anos. Os procedimentos de segurança da informação têm evoluído bastante desde o início quando a segurança

se resumia à parte física e a backups. Atualmente, essa segurança é composta de políticas, padrões, treinamentos, estratégias, softwares e hardwares.

Veremos aqui as mais diversas formas de ataque, desde as mais simples e visíveis, até as mais complexas e ocultas, no que diz respeito ao acesso indevido às informações. Compreenderemos que a segurança da informação engloba vários pontos onde cada um contribui de uma forma com o objetivo de manter sistemas, bancos de dados e conhecimentos (tácitos e/ou explicitas) protegidos.

2. SEGURANÇA DA INFORMAÇÃO

Com o aumento da utilização de sistemas de informação, tecnologia digital e comércio eletrônico, as empresas se viram obrigadas a pensar na segurança de suas informações para evitar golpes, acessos não autorizados e ameaças. Assim, essa medida surgiu para reduzir possíveis ataques aos sistemas empresariais e domésticos.

A segurança da informação é uma maneira de proteger os sistemas contra diversos ataques, preservando documentações e arquivos. Segundo Anna Carolina Aranha, a questão da segurança da informação tornou-se um tema importante na sociedade contemporânea sendo uma forte aliada de grandes empresas que armazenam e processam em computadores os segredos de seus negócios, bem como de pessoas que trocam informações eletrônicas de caráter pessoal. Todos nós acreditamos que os dados confiados às máquinas sejam mantidos confidenciais, intactos e acessíveis apenas às pessoas autorizadas.

Manter os sistemas de computador livre de ataques não é só uma questão técnica. Uma regulamentação mais rígida, a educação, a conscientização e os treinamentos dos usuários tornam o mundo digital mais seguro. Curiosamente, a questão da segurança da informação é quase tão remota quanto à humanidade. Da mesma forma, também são antigas as tentativas de “desmembrar” e ler os códigos secretos contidos em mensagens.

Colher e ou processar informações de terceiros, sem autorização sempre constitui um crime, porém, o objetivo do invasor nem sempre é conseguir algum ganho financeiro. Várias vezes a simples curiosidade ou a vontade de quebrar regras e padrões que estimula os infratores. Entender essa peculiaridade é importante tanto para as organizações como para os cidadãos comuns que se preocupam com o assunto. Trata-se de um problema cultural/social e não somente de programação, técnico ou de infraestrutura de redes e/ou comunicação.

Mesmo que atualmente exista um bom nível de consciência das empresas e consumidores em relação aos perigos dos vírus e dos ataques de hackers, há situações em que as ações para evitar os problemas não acontecem como deveriam. É bastante frequente ver empresas que adquirem (por compra ou locação) equipamentos e programas de última geração, porém não os configuram adequadamente, ou cometem erros simples na atualização e permissão de acesso.

Os programas de computador são como equipamentos, pois precisam de revisões, manutenções e cuidados constantes. Ter um conjunto Software/Hardware de última geração e não cuidar adequadamente é o mesmo que um policial comprar uma arma e deixá-la sem munição.

Segundo pesquisas, mais de 80% dos problemas de segurança seriam evitados se os programas e o hardware estivessem devidamente atualizados e configurados. Ao divulgar um arquivo de correção, com o objetivo de melhorar a segurança de determinado produto, a empresa fica exposta, pois, os hackers imediatamente tentam decodificá-lo para procurar onde está a vulnerabilidade que foi corrigida. A partir daí, podem tentar lançar ameaças contra os computadores não atualizados. Ou seja, cada atualização é necessária para prevenir um risco em potencial. Obviamente, para um hacker atento, pode ser uma dica que lhe estimule explorar o problema.

Especialistas em crimes cibernéticos afirmam que os delitos virtuais crescem em uma velocidade maior que os convencionais. Além de mais preparados tecnologicamente, os hackers estão sendo mais ousados: usam da Engenharia Social para conseguir efetivar os ataques.

Eles se utilizam de mensagens eletrônicas (e-mails e links) com atrativos, como propostas de trabalho, falsas atualizações bancárias e até a simulação de e-mails de pessoas conhecidas. Ao acessar um desses e-mails ou links, o usuário contamina equipamentos desprotegidos ou mal protegidos. Desta forma, fica cada vez mais difícil identificar as ameaças em um ambiente informatizado.

O Brasil é um dos países mais expostos aos problemas de segurança da informação. Isto ocorre, pois, o crescimento na utilização da internet e suas vantagens é muito maior do que a melhoria e aplicação dos processos de segurança. Segundo relatório da Conferência de Comércio e Desenvolvimento das Nações Unidas (Unctad), o Brasil tem a segunda Internet mais vulnerável do mundo, perdendo apenas para os Estados Unidos.

A solução não é algo simples e passa por fatores como:

- Maior regulamentação por parte do governo;
- Estímulo constante e crescente a empresas de tecnologia no sentido de produzirem recursos de segurança mais poderosos;
- Educação, conscientização e treinamento por parte dos usuários, sejam técnicos ou leigos.

Desta forma, a utilização de todas as potencialidades do mundo digital será plena com menor risco a integridade, disponibilidade e confidencialidade das informações.

2.1 Princípios básicos da segurança da informação

Disponibilidade

É a garantia de que os sistemas e as informações de um equipamento e/ou banco de dados estarão disponíveis quando necessário.

Confidencialidade

É a capacidade de controlar quem pode acessar as informações e em que condições. Assegurar que a informação só será acessível por pessoas explicitamente autorizadas, incluindo até IP de origem, datas e horários para o acesso, identificação

pessoal ou biométrica. Desta forma, é possível minimizar o acesso não autorizado aumentando a segurança.

Autenticidade

Permite a verificação da identidade de um usuário seja interno ou agente externo a um sistema ou empresa. Este conceito também se aplica a confirmação de que uma informação é autêntica ou verdadeira.

Integridade

Princípio em que as informações e dados serão armazenados e posteriormente acessados em sua forma original, sem alterações realizadas por terceiros, exceto com a devida autorização. Mesmo manipulada, a informação deve manter todas as características originais estabelecidas pelo seu proprietário.

Auditoria

É a possibilidade de rastrear a informação pelos vários passos pelos quais a informação "transitou", bem com o processamento que ela sofreu, identificando os locais, horários e usuários de cada passo. Assim é possível avaliar o histórico dos eventos em um sistema e determinar como ocorreu a falha de segurança.

É possível também, através da análise dos logs, identificar os usuários que tiveram o contato com a informação.

Privacidade

É a limitação do acesso às informações. É a garantia à preservação.

Legalidade

É a garantia de legalidade de uma informação de acordo com a legislação vigente.

Não Repúdio (Irretratabilidade – não pode ser desfeito)

Não há como "dizer não" sobre um sistema que foi alterado ou sobre um dado recebido, ou seja, um usuário não poderá negar falsamente a autoria de uma informação.

2.2 Ameaças

Neste caso, a ameaça ocorre quando há uma ação sobre um sistema ou sobre um processo utilizando uma determinada vulnerabilidade e causa um problema ou consequência, tais como: divulgação indevida, roubo de identidade, prejuízo financeiro e prejuízo de visibilidade.

As ameaças podem ser:

De origem natural: ligados a eventos da natureza, como terremotos, tornados ou enchentes;

Involuntárias: erro humano causado por pessoas desconhecidas ou pela falta de energia elétrica.

Voluntárias: em que hackers acessam sistemas com o intuito de disseminar de causar danos.

Tipos de Ameaça

- **Ameaça Inteligente:** Ocorre quando o invasor possui capacidade técnica e operacional para fazer uso das vulnerabilidades do sistema.
- **Ameaça de Análise:** Ocorre após um período de análise onde são descobertas as possíveis vulnerabilidades e as respectivas consequências da ameaça a um sistema.

2.3 Ataques

Um ataque pode ocorrer a partir de um furto a um sistema de segurança com o objetivo intuito de invadir sistemas, bancos de dados e serviços. Ele pode ser dividido em:

- **Ativo:** onde os dados são alterados.
- **Passivo:** onde os dados são liberados.
- **Destrutivo:** onde os dados são destruídos ou o acesso a eles fica restrito.

Os ataques ocorrem somente em sistemas vulneráveis. Neste caso, a vulnerabilidade pode ser física, lógica ou engenharia social.

Tipos de ataque

Cavalo de Troia

O cavalo de troia ou trojan horse é um programa malicioso e vem disfarçado em outro software. Baixar programas da Internet sem o devido cuidado é uma ótima maneira de instalar um cavalo de troia. Estes programas instalam o cavalo de troia, que abre uma porta do equipamento e que será utilizada para invasão. Eles se dedicam a roubar senhas e outros dados sigilosos. São exemplos de trojans:

- NetBus,
- Back Orifice e
- SubSeven.

Quebra de Senha

O cracker é um programa usado pelo hacker para descobrir uma senha de acesso a um sistema. O método mais comum consiste em testar sucessivamente várias sequencias de palavras até encontrar a senha correta.

Denial Of Service (DOS)

Este ataque consiste na sobrecarga de servidor com uma quantidade excessiva de solicitações de serviços. Há variações, como os ataques distribuídos de negação de serviço (DDoS). Neste caso, o invasor ataca muitos computadores e instala neles um software oculto, como o Tribal Flood Network ou o Trinoo. Estes programas, quando acionados, bombardeiam o servidor-alvo com solicitações e este, por sua vez, fica inoperante, em função do excesso de solicitações.

Mail Bomb

É a técnica de sobrecarregar um computador com e-mails. Normalmente, o agressor usa um programa para gerar um fluxo contínuo de e-mails e envia-los uma determinada caixa postal. A sobrecarga tende a provocar negação de serviço no servidor de e-mail (mail server).

Phreaking

É o uso não autorizado de linhas telefônicas, fixas ou celulares. Com o aumento da segurança por parte das companhias telefônicas, essas técnicas foram se tornando mais complexas e inteligentes. Hoje, o phreaking é uma atividade elaborada e que poucos hackers dominam.

Scanners de Portas

Eles são programas que buscam portas TCP abertas, no computador, por onde é efetuada a invasão. Uma forma de evitar que o usuário perceba a varredura é testar as portas por vários dias e em horários aleatórios.

Smurf

É outra forma de ataque de negação de serviço. O agressor envia uma rápida sequência de solicitações de Ping a um endereço de broadcast, usando spoofing (técnica de se fazer passar por outro equipamento). O cracker direciona as mensagens do servidor de broadcast para o endereço da vítima. Assim o alvo é “derrubado” pelo excesso de solicitações de Ping.

Sniffing

O sniffer é um programa ou dispositivo que analisa o tráfego da rede. Eles são muito úteis no gerenciamento de redes, porém, nas mãos de hackers permitem roubar senhas e outras informações sigilosas não criptografadas.

Spoofing

É a técnica de se fazer passar por outro equipamento da rede com o objetivo de acessar um sistema. Há variantes, como o spoofing de IP. O processo consiste em usar um programa que altere o cabeçalho dos pacotes IP. Desta forma, eles parecem vir de outra máquina.

Scamming

Esta técnica tem o objetivo de colher senhas e números de contas bancárias através de e-mails falsos oferecendo serviços, simulando a página do banco.

Vírus

Prevenção

- Instale e atualize, de preferência diariamente, um programa de antivírus confiável, assim como as assinaturas deles;

- Configure o antivírus para verificar os arquivos obtidos pela Internet, discos rígidos (HDs) e unidades removíveis, como CDs, DVDs e pen drives;

- Desabilite o “auto execução” de arquivos anexados às mensagens do seu programa de leitura de e-mails;

- Não execute ou abra arquivos recebidos por e-mail ou por outras fontes, mesmo que venham de pessoas conhecidas. Caso seja necessário abrir o arquivo, certifique-se que ele foi analisado pelo programa antivírus;

- Utilize, na elaboração de documentos, formatos menos suscetíveis à propagação de vírus, tais como RTF, PDF ou PostScript;

- Não utilize, no caso de arquivos comprimidos, o formato executável. Utilize o próprio formato compactado, como, por exemplo, Zip ou Gzip.

Worms, Bots e Botnets

Prevenção

- Siga todas as recomendações para prevenção contra vírus;

- Mantenha o sistema operacional e demais softwares sempre atualizados;

- Aplique todas as correções de segurança (patches) disponibilizadas pelos fabricantes para corrigir eventuais vulnerabilidades existentes nos Softwares utilizados;

- Instale um firewall pessoal, que em alguns casos pode evitar que uma vulnerabilidade existente seja explorada ou que um worm ou bot se propague.

3. CONTROLE DE SEGURANÇA

Autenticar e Autorizar

Autorizar é permitir ou negar acesso a um sistema utilizando controles de acesso com o objetivo de criar perfis. Com esses perfis, é possível definir, por exemplo, as tarefas que serão realizadas por determinado usuário ou grupo de usuários.

Autenticar é a comprovação do acesso de um usuário a um sistema, ou seja, se está sendo feito por ele mesmo. Ela é importante, pois, limita o controle de acesso e autoriza somente determinadas pessoas acessarem uma informação.

3.1 Processo de Autenticação

- Identificação positiva: Está relacionado a uma informação. Ocorre quando o usuário possui uma senha de acesso.

- Identificação proprietária: O usuário possui algum instrumento durante a etapa de identificação, como um cartão ou um eToken.

- Identificação Biométrica: Neste caso, o usuário se identifica através de uma parte do corpo, como impressão digital, Iris etc.

Em relação às senhas, uma dica importante é que você sempre crie senhas que possuam pelo menos oito caracteres, com letras, números e símbolos. Não utilize seu nome, sobrenome, nomes de animais de estimação, placas de carros, números de telefones ou datas que possam tenham relação com você. Procure alterá-las com frequência e faça com que sejam diferentes para cada serviço. Se você compartilha seu computador com outras pessoas, crie usuários com privilégios normais.

4. INCIDENTE DE SEGURANÇA E USO ABUSIVO NA REDE

O incidente de segurança está relacionado a problemas ligados aos sistemas de computação ou às redes de computadores. Pode ser identificado por acessos não autorizados, mudanças no sistema sem prévia autorização ou sem conhecimento da execução, tentativas de acesso aos dados de um sistema etc.

O uso abusivo na rede está ligado a características específicas como envio de spams e correntes, distribuição de documentação protegida por direito autoral, uso indevido da internet para ameaçar e difamar pessoas, ataques a outros computadores etc.

4.1 Registros de Eventos (logs)

Os logs são registros de tarefas realizados por programas de computador. Normalmente os firewalls identificam estes logs. Os logs podem ser detectados no momento em que um invasor tenta acessar um computador e é impedido pelo firewall.

A Verificação periódica dos logs do firewall e dos IDSs que estejam instalados no computador é de extrema importância, pois pode evitar ou minimizar as tentativas de ataques.

5. ESTUDOS DAS NORMAS ISO 27000 – APLICAÇÃO DE NORMAS, PADRÕES INTERNACIONAIS E CERTIFICAÇÃO

Muitas vezes não tratamos as normas com a devida importância por entendermos ser algo dispensável. Ledo engano! As normas são criadas com base em acordos, cooperações, estudos e avaliações por um órgão com conhecimento e competência para tal. Elas sugerem um conjunto de boas práticas para execução e/ou produção em um determinado tema.

O objetivo é fazer que aquilo que será produzido cumpra um padrão de qualidade e funcionamento. Este produto pode ser um software, eletrodoméstico, edifício, veículo, seminário, palestra etc. Diante desse fato, é importante ter a devida atenção e compreensão dos conceitos que serão mostrados e a forma como se relacionam, de modo que sejam aplicados da melhor forma.

As normas da série ISO/IEC 27000 tratam do SGSI (Sistema de Gestão de Segurança da Informação). A segurança da informação não está exclusivamente associada ao conceito tecnológico, apesar de muitas pessoas acreditarem que seja desta forma. O SGSI é um modo de segurança para todos os tipos de dados e informações. Está intimamente associado aos pilares da segurança da informação que são: confidencialidade, integridade, disponibilidade e autenticidade, já vistos anteriormente.

A ISO (International Organization for Standardization) e a IEC (International Electrotechnical Commission) compõem um sistema especializado de normatização mundial. Os organismos membros da ISO ou da IEC auxiliam no desenvolvimento de normas internacionais utilizando comitês técnicos definidos pela organização para tratar de assuntos técnicos. Estes comitês colaboram em áreas de interesse mútuo. Outras organizações internacionais, governamentais e ligadas a ISO e a IEC também podem atuar. Na área de TI, a ISO e a IEC criaram um comitê associando ISO/ IEC / JTC1.

5.1 Objetivos e funções - ISO/IEC 27000

A norma ISO/IEC 27000, na realidade, é um conjunto de normas com várias séries, e cada uma delas tem uma função (ou objetivo) específica, porém todas elas tratam da criação, manutenção, melhoria, revisão, funcionamento e análise de um SGSI. As normas desta série estão relacionadas à segurança da informação. Este conceito está além dos pontos puramente ligados à informática. Ainda assim, estão lado a lado.

O SGSI representa formas para a segurança para todos os tipos de dados, informações e do conhecimento produzido (ativos de TI). As diretrizes abrangem desde os primeiros passos na implementação de um SGSI, até áreas específicas, tais como orientações para empresas parceiras na certificação ou auditoria que também queiram implementar um SGSI.

5.1.1 Critérios para certificação

As normas 27001 e 27002 devem ser usadas em conjunto. Elas são as mais conhecidas da família ISO 27000 sendo que o certificado da ISO 27002 é para profissionais da área. Seus códigos e orientações facilitam a obtenção do certificado ISO 27001, que é direcionado para empresas. Cada norma tem critérios diferentes para a certificação.

Semelhante às normas ISO 9000 e ISO 14000, a norma 27001 segue o padrão para a certificação de outros sistemas de gestão da ISO. Além da questão específica do sistema de gestão de segurança da informação, é necessário atenção ao funcionamento, monitoramento e melhoria do sistema. A certificação é realizada em duas partes: sendo que a primeira é uma revisão documental, a segunda é detalhada, semelhante a uma auditoria. Veremos mais sobre isto adiante.

A família ISO/IEC 27000 possui diversas normas relacionadas à SGSI. As mais conhecidas são:

- **ISO/IEC 27000:** São informações básicas sobre as normas desta série (Vocabulários, objetivos e normas).
- **ISO/IEC 27001:** Bases para a implementação de um SGSI em uma organização. Ela mostra a forma adequada de estabelecer um sistema de gestão de segurança da informação, avaliado e certificado de forma independente. Ela trata dos seguintes tópicos:

➢ Compreensão das necessidades e a importância da política da segurança da informação;
➢ Implantar e manter controles para gestão de riscos;
➢ Acompanhar a performance, eficiência e eficácia da PSI;
➢ Estimular melhoria contínua. (Ciclo PDCA).

- **ISO/IEC 27002:** Certificação profissional traz códigos de práticas para profissionais. Ela mostra diretrizes para práticas de gestão de segurança da informação e normas de segurança da informação para as organizações, inclusive a seleção, a implementação e o gerenciamento de controles, levando em conta os ambientes de risco da segurança da informação da organização. O resultado da análise de riscos irá determinar quais as ações de controle mais adequadas na gestão destes riscos. Esta norma está composta de tópicos e respectivos controles. Estes podem ou não ser implantados, dependendo do tipo, tamanho e necessidade da organização.

  Alguns destes tópicos são:

- Organização da segurança da informação;
- Gerenciamento de ativos;
- PSI (Política de Segurança da Informação);
- Segurança de RH;
- Gerenciamento de comunicações e operações;
- Segurança física e de acesso;
- Aquisição, desenvolvimento e manutenção de sistemas de informação;
- Conformidade;
- Gerenciamento de incidentes da segurança da informação;
- Gerenciamento da continuidade de negócios.

- **ISO/IEC 27003:** Diretrizes mais específicas para implementação do SGSI. Nele, concentram-se os aspectos críticos para a implantação e projeto bem sucedido de um SGSI, desde a concepção até a preparação da implantação, incluindo aí o processo de aprovação da direção.
- **ISO/IEC 27004:** Normas sobre as métricas e relatórios do SGSI com o objetivo de avaliar a eficácia do SGSI implementado, além dos controles e/ou grupos de controles. É fundamental lembrar que as métricas e as respectivas avaliações são de extrema importância para conhecer, controlar e melhorar processos, políticas e procedimentos. Desta forma, é possível identificar problemas ou falhas de implantação e execução.
- **ISO/IEC 27005:** Norma sobre gestão de riscos do SGSI. Estabelece diretrizes para o processo de gestão de riscos de segurança da informação. Deve permitir

que o processo de segurança da informação ocorra de maneira eficaz, eficiente e sem interrupções ao longo do tempo. É fundamental que um gestor de riscos tenha uma visão de topo. Desta forma, a criação de processos integrados na gestão de riscos será facilitada. Além disso, o foco deve ser na prevenção. Veremos também que planos alternativos em caso de sinistro farão toda a diferença para a estratégia organizacional.

- **ISO/IEC 27006:** Norma sobre auditoria e certificação de SGSI, especificando requisitos e fornecendo orientações para empresas e/ou órgãos que prestem serviços de certificação e auditoria em um SGSI. Ela pode ser utilizada como referência para acreditação, avaliação de pares ou outros processos de auditoria. A área de atuação de auditorias em Sistemas de Gestão de Segurança da Informação está entre a segurança física e lógica da informação até a adequação de conformidade com a legislação vigente e obrigações contratuais.

Não promover auditorias poderá camuflar insuficiências do SGSI. Dependendo da profundidade destas insuficiências, estas poderão se converter em deficiências, gerando riscos para os dados e informações.

6. RELACIONAMENTO ENTRE AS NORMNAS DA SÉRIE ISO/IEC 27000

As Normas da série ISO/IEC 27000 tratam do “percurso” para o desenvolvimento de um Sistema de Gestão de Segurança da Informação (SGSI) nas organizações de qualquer tamanho ou setor. Isto é muito importante, pois com a velocidade da produção de informações, é fundamental que o armazenamento e proteção sejam fatores determinantes ao sucesso das estratégias nestas organizações. Um SGSI abrange todas as atividades de gestão e suporte a esta gestão importantes para a segurança da informação.

Na atualidade, informação (gerando conhecimento) é um dos pilares para o sucesso. Com este aumento crescente, aumenta também dependência das empresas

em relação aos Sistemas e Tecnologias da Informação. Sabendo do valor da informação, é fundamental que elas sejam produzidas e armazenadas de forma segura, eficiente e eficaz. O SGSI proporciona, dentre outras facilidades, a gestão dos riscos da segurança da informação garantindo que esta não seja negada, não se torne indisponível, não se perca (destruída ou danificada), não seja divulgada sem autorização ou roubada.

A informação é um dos ativos valiosos que envolvem a organização gerando valor para o negócio. Sendo assim, a proteção desta informação é de extrema importância, pois interfere diretamente na estratégia do negócio.

Análise de Risco é um dos instrumentos utilizados para garantir a segurança da informação. Esta análise deve identificar todos os riscos, mostrando as possíveis soluções para eliminar, transferir ou minimizar os riscos. As ameaças são ações, que quando exploradas, podem gerar vulnerabilidade e permitir ataques, provocando incidentes e comprometendo as informações, gerando perda de confidencialidade, disponibilidade e integridade.

As ameaças podem ser classificadas em três tipos:

- ameaças físicas: decorrentes de fenômenos naturais;
- ameaças tecnológicas: provocados por hackers, invasores, vírus, e também por falhas técnicas (hardware e software);
- ameaças humanas: São as mais perigosas, provocadas por ladrões e espiões (gerando fraudes e roubos). Normalmente, passam pela engenharia social mencionada anteriormente.

Com a evolução tecnológica e a facilidade de acesso às informações, é de responsabilidade das organizações adotar e implantar ações de proteção em relação às ameaças das quais são alvo.

É o objetivo de a Gestão de Segurança de Informação manter a qualidade das informações tratando adequadamente da confidencialidade, integridade e disponibilidade. As normas da série ISO/IEC 27000 foram produzidas de modo a ser o padrão mundial para a Segurança da Informação.

A série ISO 27000 constitui um padrão de certificação de sistemas de gestão promovido pela ISO, adequado à produção e implementação de Sistemas de Gestão de Segurança da Informação (SGSI), estabelecendo políticas de segurança e controles adequados. Como vimos, cada uma das normas da série ISO/IEC 27000 possui uma função que se relacionam. A família de normas da ISO/IEC 27000 possui padrões que estabelecem os requisitos para um SGSI e para sua certificação, prestando apoio e orientação aos processos e necessidades do ciclo PDCA (Qualidade Total).

A figura abaixo relaciona o SGSI ao ciclo PDCA.

Fonte: Google imagens

6.1 Benefícios da Aplicação da Norma ISO/IEC 27000 e sua série

O volume de informações disponibilizadas às organizações, além de crescente, é de vital importância estratégica a elas. Visualizar os benefícios e relacioná-los ao cotidiano das empresas é fator determinante na implantação dos sistemas de segurança. Os principais benefícios da norma ISO/IEC 27000 são:

- estabelecer uma metodologia clara de Gestão da Segurança: é de extrema importância, pois a clareza facilita o entendimento e a disseminação do conhecimento;
- reduzir o risco de perda, roubo ou alteração da informação: já vimos que a informação é o principal ativo de uma organização. Perda de ativo implica em perdas financeiras, dentre outras;
- acessar as informações por meio de medidas de segurança: isto é fundamental, pois formas corretas e seguras no acesso à informação evitam que usuários não autorizados monitorem e/ou acessem indevidamente;
- aplicar a Gestão adequada de pessoas a todos os envolvidos na organização: já sabemos que o elo mais fraco no controle e gestão da segurança da informação é composto por pessoas. A correta gestão é fator determinante à segurança;
- aumentar a segurança em relação à gestão de processos: processos mal gerenciados podem gerar falhas e vulnerabilidades. Isto também implicará no risco de um acesso não autorizado e perda de informações;
- aplicar a legislação sobre informação pessoal e propriedade intelectual: a legislação permite que pendências jurídicas sejam resolvidas aos olhos jurídicos. Com a devida clareza isto previne ataques por descuido ou falta de informação;
- controlar e verificar continuamente os riscos e os seus controles: isto faz parte dos processos de melhoria contínua que podem ser aplicados a qualquer área do conhecimento. Verificações constantes implicam em aprimoramento;
- garantir a confidencialidade e a qualidade comercial: o bom gerenciamento permite que a informação permaneça confidencial, gerando ótima visibilidade estratégica da organização.

7. DIFICULDADES PARA IMPLANTAÇÃO DE UM SGSI

A Implantação, o desenvolvimento e a manutenção de um SGSI nas organizações, não é tão simples quanto parece. Existem várias dificuldades que devem ser vencidas. Elas serão descritas abaixo:

- dificuldade na definição no escopo: muitas vezes, pelo levantamento insuficiente de requisitos e coleta de dados, a definição do escopo fica inadequada, podendo gerar revisões e dificuldades desnecessárias. Quando isto ocorre, tanto o desenvolvimento quanto a implantação do SGSI ficam prejudicados. Isto irá provocar o retrabalho e possíveis perdas para a organização;
- dificuldade em desenvolver uma abordagem sistemática, clara e simples na gestão dos riscos: a gestão dos riscos é uma área extremamente importante, pois é nela que os possíveis riscos são identificados e a forma de tratá-los é definida de acordo com cada caso. Tratar isto com simplicidade e clareza pode ser a diferença entre o sucesso ou o fracasso na implantação do SGSI;
- dificuldade em testar os planos de continuidade do negócio: muitas vezes não há ambientes de simulação ou, quando existem, não são adequados. Desta forma, os testes dos planos de continuidade do negócio ficam incompletos, inconclusivos ou inexistentes, podendo gerar graves consequências em caso de uma crise;
- designar indevidamente a área de TI no desenvolvimento do projeto: por falta de definição ou compreensão por par te das outras, a área de TI fica encarregada do desenvolvimento do projeto e, como vimos, o SGSI não é exclusivo na gestão de informações de tecnologia. O gestor terá que buscar a integração das áreas e pessoas envolvidas nos processos e procedimentos.

Desta forma, o SGSI será mais completo, coeso e abrangente;

- visão incorreta no estabelecimento dos parâmetros dos controles definidos na norma: isto ocorre quando a leitura e/ou interpretação da norma é ineficiente, podendo gerar retrabalho em fases críticas da implantação do SGSI. O gestor terá que ficar muito atento neste ponto, pois estudos mostram que o custo do

“retrabalho” normalmente é maior do que o do próprio trabalho. Além do aumento financeiro, este retrabalho pode gerar problemas como refugo, custo de tempo perdido, redução da confiança por par te dos stakeholders, dentre outros;

- ausência da ação correta ao identificar e usar controles além da norma: ocorre quando a gestão da implantação não assume uma visão de topo. Ou seja, “o que será feito com assuntos e problemas não previstos na norma?”. Muitas vezes (na maioria dos casos), ocorrem situações não previstas e/ou definidas nas normas. E aí, como agir? Neste momento, o gestor terá que utilizar seus conhecimentos e experiências, além de contar com profissionais que possuam o conhecimento no problema que será tratado;
- pessoal e Orçamento com limitações: muitas vezes, principalmente no cenário econômico atual, será necessário a convivência da necessidade de desenvolver e implantar o SGSI com as restrições financeiras ou de pessoal. Mesmo com as adversidades, a equipe de gestão terá que encontrar soluções adequadas a este cenário. Além disto, sabemos que no relacionamento humano; por mais profissional que as pessoas busquem ser, sempre há conflitos e jogos de interesse. Isto pode dificultar o desenvolvimento e implantação do SGSI. Caberá ao gestor tratar este ponto, utilizando técnicas de motivação e de gestão de pessoas.

Cada um destes fatores tem implicações próprias e peculiares ao tipo e tamanho da organização onde o SGSI será implantado. Porém, independente da dificuldade, ela deve ser transposta, pois o objetivo final (Implantação consistente) deve ser cumprido.

Principais melhorias nas organizações com a implantação de um SGSI

Entende-se que, quando há uma proposta de novas implantações em uma organização, sejam estas implantações em qualquer área, elas vão trazer melhorias que justifiquem o projeto. Estas melhorias podem abranger várias ou todas as áreas da empresa.

No nosso caso, as melhorias irão tratar de um assunto extremamente estratégico para a empresa, este se refere às informações e ao conhecimento: ferramentas de evolução e competitividade. Ao implantar o SGSI, esperam-se as seguintes melhorias:

- cumprimento dos objetivos organizacionais de segurança da informação;
- satisfação dos requisitos de segurança de clientes e parceiros de negócios;
- melhoria nos seus planos e atividades de curto e longo prazos;
- organização e adequação na gestão dos seus ativos de informação promovendo a melhoria contínua.

8. ESTUDO DAS NORMAS ISO 27005 e ISO 31000 – APLICAÇÕES DE NORMAS E PADRÕES INTERNACIONAIS

As Organizações em todos os planos, níveis e esferas, sejam públicas ou privadas, estão preocupadas com a segurança de suas informações. Isto porque as ameaças estão cada vez mais diversificadas e perigosas, comprometendo as informações. A gerência deste ponto é de total prioridade de suas áreas de TI. A norma ISO 27005 se bem aplicada nas organizações, irá permitir que as mesmas administrem melhor tais riscos. As ameaças têm duas vertentes: acidentais ou intencionais. Em ambos os casos, elas têm relação com os aspectos físicos e ambientais e quanto à aplicação e ao uso dos sistemas de TI. As ameaças podem ser de diversos tipos (furto de documentos e equipamentos, espionagem a distância, escuta não-autorizada, falsidade de identificação digital, fenômenos da natureza, incêndio, inundação e radiação eletromagnética)

As consequências dessas ameaças podem ser traduzidas por vários impactos nos negócios das organizações como, por exemplo, perdas financeiras, paralização de serviços essenciais, perda de confiança dos clientes, pane no fornecimento de

energia e falhas de telecomunicações. Conforme já vimos, as normas são criadas com base em acordos, cooperações, estudos e avaliações, por um órgão com conhecimento e competência para tal. Logo, é importante a devida atenção, compreensão e sua correta aplicação. As normas propõem várias técnicas a serem adequadas à empresa. Veremos que uma boa política de gestão da infraestrutura com controles de acessos, físicos e lógicos bem definidos realmente minimizam grande parte dos riscos. Elas mostram também que manter a redundância dos dados, informações e conhecimentos, além de mantê-los o mais restrito possível (dentro das estratégias do negócio), é uma das boas práticas propostas.

8.1 Conceitos associados

Antes de tratarmos das normas, é importante conhecermos alguns conceitos que são importantes para compreensão dos assuntos que veremos aqui. É muito importante que os conheçamos, pois permitirá integrar os conhecimentos e facilitar o entendimento dos casos onde seja necessário.

Risco: probabilidade de que algo não tenha sucesso ou não fique de acordo com o proposto ou esperado, por motivos incertos; eles podem ser provocados ou serem resultado de ocorrências eventuais / naturais. Muitas vezes o risco pode ser previsto e tratado de modo que não ocorra ou tenha uma baixa probabilidade de ocorrência.

Gestão de riscos: atitudes, políticas, processos e procedimentos, elaborados e coordenados pelas organizações, na figura dos gestores, de modo que os riscos sejam tratados da melhor forma, de acordo com as possibilidades e intenções organizacionais.

Estrutura da gestão de riscos: todos os itens onde as organizações atuam para a elaboração, implantação, observação, análise e melhoria contínua do gerenciamento de riscos por toda a empresa. Esta estrutura envolve processos, tecnologias e pessoas.

Política de gestão de riscos: postura organizacional em relação às diretrizes e intenções em relação à gestão de riscos. Esta política deverá estar alinhada com as estratégias e possibilidades da organização. Veremos que em muitos casos, as empresas preferem correr um determinado risco, a investir no tratamento dele.

Atitude perante o risco: forma de atuação da organização com o objetivo de avaliar, assumir, buscar (em alguns casos), manter e afastar-se do risco. Assim como a política de gestão de riscos, a atitude deve estar alinhada com as estratégias e possibilidades da organização.

Aversão ao risco: postura onde a organização objetiva afastar-se dos riscos. Isto nem sempre ocorre, pois há tipos de riscos em que é melhor aceitar a possibilidade de sua ocorrência do que preveni-lo.

Plano de gestão de riscos: protótipo da estrutura da gestão de riscos, com a função de detalhar os recursos, a abordagem e os componentes de gestão que serão aplicados no seu gerenciamento. Este protótipo deve levar em conta a estratégia de negócios da empresa, bem como um estudo profundo do impacto de um risco não tratado.

Atenção ao risco: tipo e quantidade de riscos que uma empresa tem aptidão para assumir, manter e buscar. É um tópico muito importante, pois uma avaliação indevida, neste caso, poderá provocar uma interpretação errada e consequentes perdas financeiras.

Proprietário do risco: entidade, pessoa ou organização que possui a autoridade e responsabilidade no gerenciamento do risco. Este gerenciamento envolve, entre outros pontos, as consequências da ocorrência de possíveis ameaças previstas e não tratadas previamente.

Processo de gestão de riscos: fazer com que as práticas, procedimentos e políticas de gerenciamento sejam aplicados sistematicamente às atividades de definição do contexto, comunicação, pesquisa, análise, avaliação, tratamento, monitoramento dos riscos.

Identificação dos riscos: atitudes e procedimentos de buscar, reconhecer e descrever os riscos. Esta identificação deve envolver a todos os interessados da

organização, pois por se tratar de uma das fases iniciais no gerenciamento de riscos, atitudes erradas e/ou incompletas nesta fase provocarão problemas ligados aos riscos identificados indevidamente ou não identificados.

Processo de avaliação de riscos: procedimentos gerais de avaliação dos riscos identificados, bem como sua abrangência, além de propor diretrizes para o devido tratamento.

Perfil de risco: descrição de um conjunto qualquer de riscos presentes na organização. Esta descrição também deverá estar alinhada com as estratégias de negócios da organização.

Análise de riscos: processo pelo qual se busca compreender a natureza do risco e determinar o nível do mesmo. Deve-se utilizar toda informação e conhecimento disponível de modo a conhecer, de forma mais profunda, todos os parâmetros e condições que poderão interferir nos riscos, a possibilidade, frequência de ocorrer e os impactos, caso ocorram.

Fonte de risco: qualquer componente que possa originar os riscos, mesmo que este componente atue em conjunto com outro ou tenha como origem uma fonte externa em relação à organização.

Critérios de risco: pontos referenciais que objetiva avaliar um determinado risco. Estes pontos são construídos com base na organização, suas estratégias, atuação no mercado bem como projeções para o futuro.

Nível de risco: dimensão de um risco. É composto pela combinação das probabilidades e consequências da ocorrência de um risco. Este nível não é um conceito isolado, pois deve levar em conta outros parâmetros como o mercado, clientes, parceiros e toda a parte interessada (stakeholders.)

Avaliação de riscos: procedimentos em que são comparados os resultados da análise de riscos com os critérios de risco. O objetivo é avaliar se um risco ou sua dimensão está dentro dos padrões aceitáveis, definidos e aprovados pela organização.

Tratamento de riscos: Conjunto das tarefas, políticas e processos que unidos têm a função para excluir, alterar, aceitar, transferir ou mitigar riscos. A decisão de qual opção escolher irá variar de acordo com parâmetros organizacionais diversos (Situação do mercado, participação da organização, capacidade de investimento etc.)

Parte interessada: pessoas e/ou organizações que podem afetar, serem afetadas, ou perceberem–se afetada por uma decisão ou atividade que envolva a organização. Conhecido também como stakeholder.

Estabelecimento do contexto: estruturação de um cenário, levando em conta os parâmetros externos e internos bem como o gerenciamento dos riscos, e definição do escopo e dos critérios de risco no seu gerenciamento.

Contexto externo: ambiente externo onde a empresa quer atingir seus objetivos (mercado, políticas públicas, condições ambientais etc.).

Contexto interno: ambiente interno (organizacional) onde a empresa quer atingir seus objetivos. Os objetivos podem ser:

- estratégias, objetivos e políticas implantadas;
- status organizacional no que se refere ao conhecimento e aos recursos (sistemas, recursos financeiros, tempo, processos, pessoas e tecnologias);
- governança, estrutura organizacional, funções e responsabilidades;
- atuação das partes internas interessadas e o relacionamento entre elas;
- fluxos e sistemas de informação e influência dos processos informais e formais na tomada de decisão;
- normas, modelos e diretrizes organizacionais;
- a própria cultura da empresa;
- tipo das relações contratuais sejam formais, explicitas ou tácitas.

Comunicação e consulta: é tudo o que é feito pela organização, de forma contínua, no sentido de disseminar e obter informações relativas ao gerenciamento dos riscos. Evento: é uma ocorrência. Algo que promove uma alteração em alguma situação ou conjunto delas.

Consequência: resultado de um evento que altera o percurso ou objetivos.

Probabilidade: chance de que algum evento aconteça.

Controle: medidas com o objetivo de alterar o risco. Elas podem ser dispositivas, práticas, processos, políticas, etc. Pode ocorrer de o controle não exercer o efeito desejado sobre o risco.

Risco residual: é o risco que permanece após o tratamento dos riscos. Monitoramento: ato de identificar e acompanhar continuamente uma determinada situação, com o objetivo de detectar alterações na performance esperada.

Análise crítica: atividade onde são verificadas a suficiência, adequação, eficiência e eficácia de um determinado assunto de modo que os objetivos sejam atingidos. Esta análise pode ser aplicada ao processo e à estrutura da gestão bem como aos controles dos riscos conforme descrito abaixo. É importante lembrar que estes conceitos se interconectam devendo ser avaliados de forma integrada.

9. PRINCÍPIOS DA GESTÃO

A gestão de riscos é parte integrante de todos os processos organizacionais: pois não é uma atividade autônoma separada dos demais processos e atividades da organização. Esta gestão compõe as responsabilidades da administração e é parte dos processos organizacionais, tais como o planejamento estratégico e os processos de gestão de mudanças e gestão de projetos.

A gestão de riscos aborda explicitamente a incerteza: isto porque risco e incerteza estão ligados. A incerteza de que algo pode não funcionar está associada aos próprios riscos.

A gestão de riscos é sistemática, estruturada e oportuna: ela contribui para a eficiência e para os resultados confiáveis, consistentes e comparáveis.

A gestão de riscos é parte da tomada de decisões: já que auxilia os responsáveis pelas decisões a fazer escolhas conscientes, priorizando ações e escolhendo formas diferentes de agir.

A gestão de riscos baseia-se nas melhores informações disponíveis: os dados utilizados no gerenciamento de riscos são fundamentados em fontes de informação, como dados históricos, observações, previsões, experiências, estudos de especialistas. Entretanto, é importante que gestores estejam atentos às limitações ou modelagem dos dados. A possibilidade de divergências entre pontos de vistas de especialistas é também um fator a ser levado em conta.

A gestão de riscos é feita sob medida: ela deve estar alinhada à estratégia organizacional, levando em conta os contextos interno e externo com o perfil do risco.

A gestão de riscos considera fatores humanos e culturais: ela deve estar atenta e reconhecer as intenções, percepções e capacidades do pessoal (interno e externo) Isto porque eles podem dificultar ou facilitar a realização dos objetivos organizacionais.

O gerenciamento de riscos gerando e protegendo valor: isso ocorre já que a gestão de riscos proporciona maior facilidade na obtenção das metas e objetivos, aumentando o desempenho organizacional.

A gestão de riscos é transparente e inclusiva: isso é fundamental já que as partes interessadas devem estar envolvidas de forma adequada, em todos os níveis da empresa, fazendo a gestão de riscos permanecer de acordo com os objetivos organizacionais. Este fato também proporciona a devida representação das partes interessadas de modo que possam opinar e atuar corretamente.

A gestão de riscos facilita a melhoria contínua da organização: melhoria contínua deve ser uma prática constante no cotidiano da organização, incluindo a gestão de riscos, pois os riscos mudam tanto em dimensão quanto em tipo.

A gestão de riscos é dinâmica, iterativa e capaz de reagir a mudanças: Sabemos que as circunstâncias se alteram com muita frequência em qualquer área do conhecimento. Sendo assim, a gestão de riscos deve perceber e reagir às mudanças de forma rápida e eficiente.

9.1 Normas ISO / IEC 27005

Norma sobre gestão de riscos do Sistema de Gestão de Segurança da Informação (SGSI). Estabelecem diretrizes para o processo de gestão de riscos de segurança da informação. Deve permitir que o processo de segurança da informação ocorra de maneira eficaz, eficiente e sem interrupções ao longo do tempo. Esta norma dá suporte aos conceitos definidos na norma ISO 27001, (norma de requisitos de sistemas de gestão da SI), e auxilia na implementação e certificação do SGSI.

Apesar desta norma tratar a gestão de riscos de segurança da informação, ela não trata de um método específico. Por isto é necessário que cada empresa defina a melhor metodologia, de acordo com o cenário no qual se encontre.

Segundo esta norma, todas as atividades são compostas por:

- **entrada:** identifica as informações necessárias para a execução da atividade;
- **ação:** descreve a atividade;
- **diretrizes:** fornece as diretrizes para a implementação das ações;
- **saída:** identifica as informações resultantes da atividade.

É fundamental que os tópicos escopo, objetivo, métodos e critérios (avaliação, impacto e tratamento de risco) além do setor da organização, que será responsável pelo GRSI (Gerenciamento de Riscos de Segurança da Informação), sejam definidos de modo que este gerenciamento seja coeso e eficiente.

As diretrizes para a implementação desta norma são:

- definição do contexto: definir os limites e o escopo que servirão de base para a gestão de riscos;
- identificação de riscos: conhecer e relacionar os possíveis eventos que terão impacto negativo nos negócios da empresa;
- estimativa de riscos: valorar qualitativamente e/ou quantitativamente o impacto de um possível risco além de avaliar a probabilidade que aconteça;
- avaliação de riscos: estabelecer a prioridade de cada risco por meio de comparações entre os níveis estimado e aceitável, definidos pela empresa;

- tratamento do risco: criar e implantar controles com o objetivo de diminuir, reter, evitar e transferir riscos;
- aceitação do risco: os planos de tratamento do risco bem como os riscos residuais, a respectiva aprovação, devem ser documentados e aprovados pelas partes interessadas;
- comunicação do risco: a comunicação dos riscos e dos controles adotados deve ser ampla e abranger a todos os stakeholders;
- monitoramento e análise crítica de riscos: processo continuo de verificação dos riscos e respectivas causas, com o objetivo de perceber possíveis alterações nos procedimentos, fazendo com que a gestão de riscos de segurança da informação esteja em conformidade com a situação organizacional.

9.2 ISO 31000 - Princípios da Gestão de Riscos, princípios e diretrizes

Esta norma estabelece estrutura, princípios e um processo para gerir qualquer tipo de risco, de forma sistemática, transparente e confiável em qualquer situação. Ela disponibiliza os parâmetros para a gestão de risco, com os princípios e as diretrizes, além de auxiliar as empresas a gerir o risco de forma eficaz e eficiente. É referência mundial em gestão de riscos. Várias normas de gestão, com o objetivo de abordar o risco com um mesmo padrão, utilizam-se, como base nesta norma, de seus princípios, diretrizes e estrutura.

A ISO 31000 veio para ser uma referência na prática de gestão de riscos. Ela pode ser aplicada a qualquer empresa e a qualquer tipo de risco de qualquer tipo de negócio. Essa norma trata a gestão de riscos a um nível corporativo e não só no âmbito da Segurança da Informação, fornecendo detalhes de cálculos de probabilidade, avaliação de consequências.

Ela é uma norma bem ampla, tratando sobre todos os tipos de risco, sejam eles financeiros, administrativos, econômicos, de gestão, crises locais e crises mundiais. Além disso, estabelece bases para que a organização consiga prever o máximo de riscos possíveis. Com esta previsão, a organização pode estabelecer políticas internas, aliadas à norma, de modo a tratar estes riscos com as melhores práticas.

A série ISO 31000 é composta por três normas. As duas primeiras orientam a organização a construir e manter a sua gestão de riscos. A terceira (ISO Guia 73) mostra um glossário com termos pertinentes à gestão de riscos. Portanto a ISO 31000 trata dos conceitos básicos, diretrizes e princípios para a implantação da gestão de riscos. Já a ISO/IEC 31010 trata dos métodos de avaliação e gerência de riscos. Os principais benefícios da aplicação desta norma são:

- faz com que a governança e a eficiência operacional tenham ganhos significativos;
- aumenta a confiança dos stakeholders em relação à organização bem como no uso das técnicas de gestão de risco;
- reduz perdas por meio da aplicação de controles e de métodos de gestão para a análise dos riscos;
- aumenta a performance e a resiliência dos processos de gestão;
- aumenta a resposta em relação às mudanças fazendo com que fique mais eficiente protegendo a organização no seu processo de expansão.

9.3 Objetivos e aplicações da gestão de riscos e das normas ISO/IEC 27005 e ISO 31000

A Gerência de Riscos trata o risco com uma visão estatística e probabilística de sua ocorrência. As empresas que tratam e gerenciam os riscos de forma eficiente e eficaz conseguem alto nível de proteção e estabilidade além de expandir seus negócios com maior assertividade. Em relação às normas, as organizações devem integrar as melhores práticas no seu cotidiano operacional, aplicando-as de forma ampla nas práticas empresariais.

A função da Gestão de Riscos é a de minimizar perdas e seus efeitos, decorrentes dos riscos inerentes a cada tipo de negócio. São utilizadas técnicas de análises e inspeções, com o objetivo de evitar que essas perdas ocorram ou reduzindo a frequência de sua ocorrência e/ou reduzir os efeitos desses riscos, fazendo com que fiquem dentro de um valor estipulado pela organização. Não há uma forma única (ou

metodologia padrão) de Gerenciar os Riscos. Muitas vezes o que é feito é comparar os procedimentos vigentes com os padrões, avaliando as possíveis alterações.

O Gerenciamento de Riscos é um processo contínuo de busca de possíveis problemas com o objetivo de evitá-los. A avaliação de risco trata de várias nuances que podem influenciar a organização. Tais como financeiro, administrativo, operacional, expansão do negócio, limitações por imposições legais. Os riscos devem ser tratados de acordo com sua prioridade, ou seja, riscos de média probabilidade de ocorrência e alto impacto financeiro devem ser priorizados em relação aos riscos com alta probabilidade de ocorrer, porém com baixo impacto financeiro.

O conhecimento da real dimensão de um risco ocorre a partir do momento que ele é quantificado e qualificado.

- **A qualificação** é a identificação da qualidade e do tipo de risco.
- **A quantificação** é a determinação do valor da possível perda, normalmente indicada em percentual ou em valor absoluto.

Tanto o tipo de risco quanto o valor do prejuízo são muito significativos para a determinação do custo do risco. De acordo com o custo do risco, é possível elaborar um plano de tratamento das perdas ou transferir esse risco.

A transferência de um risco não isenta uma organização de todas as preocupações ou prejuízos, ainda que as perdas sejam reparadas.

Com o objetivo de criar um SGSI eficaz, são necessárias uma abordagem sistemática no gerenciamento de riscos de segurança da informação e identificar as necessidades da organização em relação aos requisitos deste tipo de segurança. É muito importante que essa abordagem seja adequada ao ambiente organizacional, além de estar alinhada aos processos de gestão de riscos corporativos. Além disso, os esforços de segurança devem tratar os riscos de maneira efetiva e no tempo adequado, sempre que necessário. É fundamental que a gestão de riscos de segurança da informação componha as atividades de gestão de segurança da informação e que seja aplicada na implementação e na operação cotidiana de um SGSI.

Essa gestão de riscos deve ser um processo contínuo e com melhoria contínua. Esse processo deve definir os cenários externo e interno, avaliar os riscos e tratá-los com um plano adequado com o objetivo de implementar o que foi estabelecido. A gestão de riscos, antes de decidir o que será ou não feito, também deve analisar os possíveis acontecimentos e suas consequências, com o objetivo de manter os riscos a um nível aceitável de acordo com o que foi proposto.

A recomendação da norma como diretrizes para sua implementação é basicamente o monitoramento contínuo da ABNT NBR ISO/IEC 27005 como segue:

- novos ativos incluídos no escopo; modificações dos valores dos ativos;
- novas ameaças que possam afetar os ativos;
- possíveis novas vulnerabilidades ou ampliação das existentes; as consequências de ameaças, vulnerabilidades e riscos avaliados em conjunto;
- incidentes relacionados à segurança da informação.

Sendo assim, podemos concluir que o processo de gestão de riscos de segurança da informação possui uma ampla atuação, podendo ser aplicado em toda a organização, seja em uma área específica, aos sistemas, controles etc.

Os principais benefícios das normas ISO/IEC 27005 e ISO/IEC 31000 como guia para a gestão de riscos são:

- facilitar a identificação de riscos;
- melhoria do entendimento, da comunicação, da possibilidade e das consequências dos riscos;
- adequação na definição e priorização das ações para reduzir a ocorrência dos riscos;
- avaliar adequadamente os riscos em relação ao negócio levando em conta a probabilidade de sua ocorrência e as possíveis consequências;
- facilitar a definição da ordem prioritária no tratamento do risco;
- melhoria da eficácia e eficiência no monitoramento do tratamento dos riscos;
- maior engajamento das partes interessadas na tomada de decisões de gestão de riscos;
- melhoria do fator “comunicação” em toda a organização, mantendo as partes interessadas informadas sobre os assuntos da gestão de riscos;

- possibilitar o monitoramento contínuo e análise crítica periódica dos riscos e do processo de sua gestão; permitir a criação de treinamentos adequados dos colaboradores em todos os níveis em relação aos riscos e das ações adequadas para cada caso;
- melhorar o foco na coleta de dados e informações com o objetivo de melhorar a abordagem da gestão de riscos.

Diferenças básicas entre as normas ISO 27005 e ISO 31000

Aplicável a todas as organizações, independentemente do tipo, porte ou setor, a norma fornece orientações para implementar os requisitos da ISO 27001, com uma abordagem de gestão de riscos, mais especificamente no processo de avaliação e tratamento de riscos em segurança da informação. Estas orientações seguem as diretrizes e terminologia da ISO 31000: Gestão de Riscos – Diretrizes, a referência internacional de gestão de riscos, o que permite manter uma linguagem comum e o alinhamento com uma estrutura de gestão de riscos corporativos.

Ambas as normas ISO 27005 e ISO 31000 fornecem diretrizes para gestão de riscos na organização, porém a ISO 31000 é uma norma genérica aplicável em qualquer tipo de risco ou atividade, enquanto a ISO 27005 é aplicada especificamente à riscos de segurança da informação.

Como principais mudanças, a nova ISO 27005 está agora mais alinhada com a ISO 31000 e a ISO/IEC 27001, o conceito de cenário de risco foi introduzido e também uma nova abordagem para identificação de riscos baseada em eventos foi contrastada com a abordagem baseada em ativos.

Ela fornece detalhes de cálculos de probabilidade, avaliação de consequências.

Existem algumas diferenças em cada uma das normas com relação a escopo, estrutura, processo e execução do processo.

Em relação escopo, ISO/IEC 31000 se aplica qualquer setor da organização em várias atividades, enquanto a ISO/IEC 27005 é uma norma voltada especificamente para a segurança da informação.

Em relação a estrutura, ISO/IEC 31000 apresenta uma visão de alto nível dos componentes necessários no gerenciamento de riscos, e o relacionamento entre os mesmos. Já a ISO/IEC 27005 apresenta uma descrição da estrutura das atividades existentes no processo, com elementos que estarão presentes em cada uma delas.

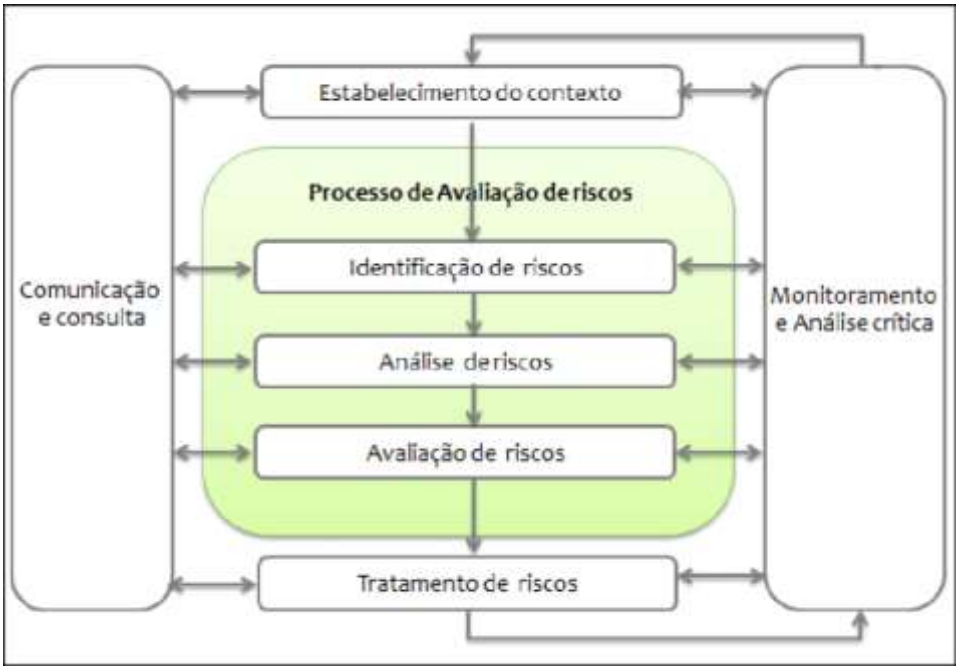
Em relação a processo, ambas apresentam um processo dividido em atividades semelhantes. Porém a ISO/IEC 31000 define sete atividades, e a ISO/IEC

27005 define seis. As atividades de análise e avaliação de riscos foram agrupadas em um só conjunto. Em relação à execução do processo, ISO/IEC 27005 sugere que a análise, avaliação e tratamento de riscos sejam executadas de forma iterativa, sendo que em cada iteração haverá maior detalhamento e aprofundamento, isso não ocorre na ISO/IEC 31000.

Cada uma das normas possui características únicas. Em resumo, a principal característica da norma ISO/IEC 31000 é fazer com que a gestão de riscos seja tratada de forma integrada na organização, aliando-se com outros padrões existentes, e no caso da ISO/IEC 27005, seu principal objetivo é atender aos requisitos exigidos para um SGSI de acordo com a ISO/IEC 27001. Desta forma, ela está alinhada à família de normas ABNT NBR ISO/IEC 27000, tratando exclusivamente da Segurança da Informação.

Comparativos na estrutura, escopo e processo

Apesar de possuírem focos diferentes, as duas normas têm o mesmo objetivo, ou seja, a gestão de riscos. Elas são similares na sua estrutura, escopo e processo. Serão explicadas rapidamente as etapas contidas na figura:



Fonte: Google

9.4 Estudo da norma ISO 22301 - Aplicação de normas e padrões internacionais

No início, quando a tecnologia da informação se aliou mais fortemente a sua segurança, as organizações passaram a compreender a importância do cuidado com preservação da informação nos seus pilares básicos (integridade, disponibilidade, autenticidade, confidencialidade). O ambiente computacional era restrito e com maior facilidade de controlar. Isso gerava um quadro maior de segurança para a informação.

Nos dias de hoje, com a expansão tecnológica e de conhecimentos, esse cenário tornou-se mais competitivo e complexo. Desta forma, o risco de acesso indevido à informação aumentou na mesma proporção. E, como sabemos, a informação é ativo de maior importância estratégica organizacional. Sendo assim, a atenção às vulnerabilidades é fundamental, pois reduz o risco de ameaças e de consequentes perdas financeiras.

Assim, aumentou-se a preocupação das empresas com a continuidade de seus negócios. Essa preocupação tornou-se ainda maior com o ocorrido em 11 de setembro de 2001 (ataque terrorista às torres gêmeas nos Estados Unidos), exigindo que normas e procedimentos relacionados à segurança da informação, fossem revistos,

reformulados e até criados. O objetivo dessa mudança de cenário foi fazer com que as organizações estivessem protegidas contra atividades que pudessem tornar inacessíveis os seus ativos de informação.

Os negócios das organizações, normalmente, baseiam-se em níveis fundamentais, nas informações e nos recursos e ser viços da Tecnologia da Informação (TI). Nesse cenário, devemos entender e avaliar como a TI trata os problemas associados que afetam o funcionamento organizacional em si.

Com isso, podem surgir algumas perguntas pertinentes: como esta área se preparou para prever, lidar e reagir a sinistros que prejudiquem o funcionamento da empresa? Caso ocorram, o que será impactado? A empresa irá parar?

Com apenas esses pontos, podemos entender a importância de um plano de gestão de continuidade no negócio.

10. CRIPTOGRAFIA, CERTIFICAÇÕES DIGITAIS, ASSINATURA DIGITAL

Conforme tratamos anteriormente, a Segurança da Informação é tratada de várias maneiras aliadas entre si, de modo que todas as nuances e variações de ataques possíveis estejam contempladas. Além disso, há muitos procedimentos, processos e políticas para assegurar que a Segurança da Informação seja estável e coesa no que se refere aos pilares da SI (integridade, confidencialidade, disponibilidade e autenticidade). Cada um desses pilares representa uma característica necessária à Segurança da Informação.

Os assuntos que trataremos aqui compõem aspectos da segurança da informação, já que a certificação digital é uma comprovação mútua de autenticidade, a criptografia é um conjunto de regras de leitura e escrita da informação e a assinatura digital é um método de validação digital. Com isso, trataremos a informação por esses três tópicos, no que se refere aos seus pilares básicos.

Há muitas maneiras de preparar senhas, tipos de acesso e formas de trocar informações. A diferença estará no nível de segurança que existirá nessa troca de informações.

Conforme já vimos, a sequência: “dados, informações e conhecimentos”, corresponde ao maior ativo que uma empresa possui. Sendo assim, a sua segurança pode representar a diferença entre o crescimento e o fracasso de uma empresa, ou ainda a confiança ou não dos stakeholders e/ou acionistas. Existem muitas formas de ataque e necessidade de defesa por meio de técnicas para gerenciar riscos e a continuidade dos negócios.

Os pontos que trataremos são de fundamental relevância para a gestão da Segurança da Informação. Cada um deles (criptografia, certificações digitais e assinatura digital) representa uma parte da Segurança da Informação e a atuação desses três pontos garante uma segurança muito maior.

Apesar de serem tópicos independentes, com as suas respectivas regras, aplicações, vulnerabilidades, vantagens e desvantagens, todos se relacionam e se completam.

Apesar de todo o esforço na utilização desses métodos para aumentar a segurança, eles são passíveis de ataques e quebras por ameaças como “força bruta”, engenharia social, etc., contudo, diminui o risco de que as informações caiam em mãos erradas, sendo violadas de alguma forma, por métodos semelhantes aos apresentados ou complementares.

10.1 Criptografia

É uma palavra formada pela junção de duas palavras gregas: kryptós, "escondido ou camuflado" e gráphein, "escrita". Em termos de segurança da informação, é uma técnica que consiste na conversão da informação da sua forma original para outra que somente possa ser lida por “alguém” que tenha a chave de

leitura. Dessa forma, alguém não autorizado terá maior dificuldade de ler a informação. Os primeiros métodos de criptografia utilizavam um único algoritmo de codificação.

Dessa maneira, era necessário que tanto o emissor quanto o receptor da informação conhecessem esse algoritmo. Porém, se um invasor conhecer esse algoritmo decifrará a mensagem, caso a intercepte.

Há duas formas principais de se fazer a criptografia, a saber:

- **Criptografia por códigos.** O objetivo é "esconder" o conteúdo da mensagem utilizando códigos predeterminados e de conhecimento entre as partes envolvidas na troca das mensagens. Sendo assim, se a mensagem for lida por pessoas não autorizadas, nada terá significado coerente. Porém, nesse tipo de solução, com o uso constante dos códigos, eles podem ser decifrados de forma mais fácil;
- **Criptografia por cifras.** É uma técnica na qual o conteúdo da mensagem é cifrado pela substituição ou mistura (ou ambos) dos caracteres da mensagem original (plain text). A decodificação ocorre, fazendo o procedimento inverso à "cifragem". Esse método é implementado com o uso de algoritmos associados a chaves, que determinarão o formato do texto criptografado.

Abaixo estão descritos os principais tipos de cifras:

- **Cifras de Transposição:** nesse caso, o conteúdo da mensagem é o mesmo (em quantidade de bytes), mas a ordem dos bytes não é a mesma. (Exemplo: LIVRO -> RLVIO).
- **Cifras de Substituição:** já nesse caso, cada byte ou grupo deles é trocado de acordo com uma tabela de substituição.

Esse método pode ser dividido em:

- **Cifra de César (cifra mono alfabética de substituição simples):** aqui cada byte da mensagem é trocado por outro, obedecendo uma tabela que pode seguir um deslocamento do byte em relação aos caracteres possíveis na tabela. O motivo pelo qual pode ser chamada de Cifra de César é que este imperador

romano quando trocava mensagens com seus generais, alterava a ordem das letras onde cada uma estava três posições à frente no alfabeto;

- **Cifra de substituição poli alfabética:** é semelhante à cifra de César, porém, mais elaborada, pois utiliza mais de uma cifra de substituição simples, em que os bytes são trocados seguidamente, assumindo valores diferentes;
- **Cifra de substituição de polígramos:** consiste na troca de um grupo de bytes e não de apenas um;
- **Cifra de substituição por deslocamento:** nesse caso, a troca dos bytes não ocorre utilizando um valor fixo. Cada byte é associado a um valor usado na troca por meio de uma regra. E como seria isso? Vejamos neste exemplo: imagine se quiséssemos cifrar a palavra "JATO" utilizando o critério de rotação "035", seria substituir "J" pela letra que está 0 (zero) posições no início do alfabeto, o "A" pela letra que está 3 posições a frente. Esse procedimento é repetido até que a cifragem seja concluída.

A principal vantagem do método das cifras em relação ao dos códigos é que não há limite para as mensagens que serão trocadas. O método das cifras também é mais seguro em relação ao dos códigos.

Com a evolução da criptografia, começou a se utilizar o conceito de chaves, dessa forma, pode-se usar o mesmo algoritmo (método) para vários receptores. Isso ocorrerá se cada um receber uma chave diferente. E ainda, se um receptor perder ou ter a segurança da chave quebrada, ela poderá ser trocada e o algoritmo será o mesmo.

Chave de criptografia: chave é um parâmetro (ou uma parte de informação), com o objetivo de controlar o algoritmo de criptografia. A variação dessa chave interfere no funcionamento do algoritmo;

Plain text (texto claro): é a informação original, não criptografada;

Chave simétrica: nesse tipo de chave, o emissor e o receptor utilizam a mesma, ou seja, é uma única chave para codificar e decodificar a informação. Há vários algoritmos que utilizam chaves simétricas tais como: o IDEA (International Data Encryption Algorithm), DES (Data Encryption Standard) e o RC (Ron's Code ou Rivest Cipher).

- **DES (Data Encryption Standard):** algoritmo criado pela IBM em 1977 que utiliza chaves de 56 bits o que equivale a 72 quatrilhões de combinações. É um valor muito grande de combinações, porém já foi quebrado. Ocorreu em 1997 por meio de um desafio promovido na internet, usando uma técnica chamada de "força bruta" (por tentativa e erro).
- **IDEA (International Data Encryption Algorithm):** Algoritmo criado em 1991 por James Massey e Xuejia Lai. Ele utiliza de chaves de 128, com estrutura parecida com a do DES. Porém, em nível de softwares o IDEA é mais fácil de ser implementado do que o DES.
- **RC (Ron's Code ou Rivest Cipher):** este algoritmo foi criado por Ron Rivest na empresa RSA Data Security, utilizado em e-mails, utilizam chaves que variam de 8 a 1024 bits. Foi lançado em várias versões, cuja principal diferença é o tamanho das chaves.

Existem outros algoritmos tais como 3DES, o AES (Advanced Encryption Standard) baseado no DES - o Twofish e sua variante Blowfish. As chaves simétricas possuem algumas desvantagens. Por exemplo, não devem ser utilizadas nos casos em que a informação tenha maior valor. Isso porque a quantidade de usuários interfere diretamente na quantidade de chaves. Além disso, como o emissor e o receptor conhecem e transmitem a mesma chave, em algum momento da transmissão, ela pode ser rastreada por pessoas não autorizadas.

Chave assimétrica ou "chave pública": este tipo de chave na realidade trabalha com duas chaves, sendo uma pública e outra privada. Funciona da seguinte forma: um emissor cria uma chave de codificação e a envia ao receptor. Essa é a chave pública. A chave privada é criada para decodificar e, por isso, é secreta. Ou ainda, o emissor cria uma chave pública e a envia a outros sites. Quando houver necessidade de algum site enviar informações criptografadas ao emissor, deverão fazê-lo usando a chave pública dele. Quando a informação chegar ao emissor, ela somente poderá ser descriptografada (decodificada) com o uso da sua chave privada. Tanto o emissor quanto o receptor alternam os papéis, alternando também a utilização das chaves pública e privada.

Processo de criptografia por chave pública

(Fonte: Google)

Os principais algoritmos que utilizam as chaves assimétricas são:

- **RSA (Rivest, Shamir and Adleman):** criado por Adi Shamir, Ron Rivest e Len Adleman nos laboratórios do MIT (Massachusetts Institute of Technology) em 1977. É um dos algoritmos mais utilizados no trato da chave assimétrica. Nele, a chave privada corresponde a dois números primos muito grandes, que são multiplicados e a chave pública é o resultado obtido.
- **ElGamal:** foi criado por Taher ElGamal, do "logaritmo discreto" como padrão de segurança. Ele é bastante usado em assinaturas digitais.
- **Criptografia Hash:** nesse tipo, através de uma string (conjunto de caracteres), é calculado um identificador digital de tamanho fixo. Esse valor é chamado de hash. Esse resultado pode ser formado por tamanhos que variam entre 16 e 512 bytes.

As principais características da função hash são:

- O valor de entrada pode ser de qualquer tamanho;
- Possui valor de saída com tamanho fixo;
- É de processamento relativamente fácil para qualquer valor de entrada;
- É uma função “one-way” (não aceita lógica reversa);
- É livre de colisão (duas funções hash não apresentam o mesmo valor).

10.2 Tipos combinados de chaves

Já que as Chaves Assimétrica e Simétrica possuem vantagens e desvantagens, criou-se um método com o objetivo de associar as vantagens de cada uma, excluindo as desvantagens. Alguns protocolos como o TLS (Transport Layer Security) e SSL (Secure Sockets Layer) se originaram dessa junção.

E como funciona essa combinação? Como a implementação da chave simétrica gera problemas como a necessidade de haver códigos secretos pré-definidos e grande capacidade de processamento, foi criada uma forma em que na primeira etapa (handshake) é usada a chave assimétrica, autenticando os pontos e usando posteriormente uma chave secreta na criptografia simétrica. Já que o algoritmo de chave pública utiliza um canal mais seguro na negociação, evitando a necessidade de mudança constante da chave, todo o restante do processo passa a ser feito usando algoritmos de chave simétrica, reduzindo muito a necessidade da alta capacidade computacional, possibilitando a utilização em comunicações intensas.

A criptografia quântica nasce com o objetivo de aprimorar a confiabilidade. Ela se utiliza das leis da física para garantir o sigilo das mensagens trocadas. Ela se baseia em uma lei natural que é o princípio da incerteza de Heisenberg. Isto é, duas mensagens são transmitidas em uma única transmissão quântica e o receptor somente pode ler uma mensagem de cada vez. É dessa incerteza natural que a criptografia quântica se aproveita.

10.3 Ataques e segurança

A análise da segurança dos algoritmos conclui que a segurança está na dificuldade ou facilidade que alguém pode decodificar mensagens sem conhecer a chave de decodificação (ou quebrar o código). Essas investidas são conhecidas como ataques, sendo que a mais simples e conhecida, nesse caso, é o ataque por força

bruta, isto é, uma tentativa e erro com o intuito de decifrar o código). Apesar de simples, ela é pouco eficiente, e em alguns casos não pode ser implementada.

Em grande parte dos ataques, utiliza-se um mix composto de equipamentos robustos e matemática computacional com o objetivo de decodificar. Esse conceito é chamado de criptoanálise.

São três os tipos de análise que usam esse método, a saber:

- **Ataque por texto conhecido:** em que o atacante utiliza dois textos, sendo um plain text e o outro é a criptografia do primeiro. Dessa forma, ele analisa os textos para descobrir a chave de criptografia para aplicar nas futuras mensagens;
- **Ataque por texto escolhido:** aqui, é possível para o atacante escolher o plain text e conseguir o seu correspondente criptografado;
- **Criptoanálise diferencial**: esse método é uma variante do método de ataque por texto escolhido. O objetivo é criptografar vários documentos semelhantes e avaliar os seus efeitos.

Todos os sistemas criptográficos possuem níveis diferentes de segurança, dependendo da facilidade ou dificuldade com que são quebrados. Só haveria um sistema realmente seguro se ele fosse “teoricamente” inquebrável, ou seja, não importaria a quantidade de texto normal ou codificado que ele nunca teria informação suficiente para quebrar as cifras ou deduzir as chaves que foram usadas.

A situação ideal de uma criptografia, é que ela não seja fundamentada em algoritmos de criptografia, mas sim, na dimensão das chaves usadas. Um algoritmo deve passar por todos os tipos de testes e por todas as formas de ataques possíveis com o objetivo de assegurar a sua resistência às ameaças. Um algoritmo é tão robusto quanto a sua resistência em relação à quebra de seu código.

Uma das formas de avaliar a força de um algoritmo é divulgar sua descrição, permitindo que sua eficiência seja discutida por muitas pessoas, em relação aos seus métodos. Sistemas que utilizam algoritmos proprietários normalmente não publicam sua especificação. Isso porque poderá mostrar os pontos fracos desse algoritmo.

Sendo assim, a situação ideal é que um sistema criptografado seja tão forte e seguro, que nem o seu criador possa decifrar uma mensagem sem a chave.

Atualmente, as chaves de criptografia correspondem a grandes sucessões de bits. Lembrando que um bit pode assumir apenas dois valores (0 ou 1), ou seja, uma chave de quatro dígitos oferecerá 16 (24) valores distintos para a chave. Por tanto, o grau de confidencialidade da mensagem é diretamente proporcional ao tamanho da chave.

Verificação de integridade e autenticação comum

O Código de Autenticação de Mensagens (Message Authentication Code - MAC) são dispositivos digitais de criptografia, que atuam com sistemas de criptografia simétrica, cujo objetivo é proteger a informação. Quando utilizado em relação à informação, esse método cria um valor (pequena porção de dados). Essa porção atua como código para o documento.

Se um atacante alterar o MAC (assim como pode alterar os dados), sem saber qual foi a chave utilizada na criação do MAC, a alteração da informação fica inviável, aumentando a segurança.

11. ASSINATURAS DIGITAIS

É um tipo específico de MAC criado por criptografa assimétrica. A assinatura de uma mensagem consiste na utilização de um procedimento chamado Message Digest (MD) que é utilizado para processar o documento. Assim como o MAC, ele gera uma pequena parte de dados conhecida como hash. A MD é uma função matemática que condensa toda a informação da mensagem em uma parte de dados com tamanho fixo. Além disso, deve haver a garantia que não houve alteração da mensagem durante a transmissão.

A assinatura digital é o resultado desse procedimento sendo uma garantia que a mensagem recebida corresponda integralmente à original. A principal razão para utilização de funções MD refere-se ao tamanho do bloco de dados que será

criptografado na obtenção da assinatura. Em ambos os casos, o objetivo é possibilitar que a informação trafegue de um ponto a outro, e o receptor deve comprovar que a mensagem realmente veio do remetente que confirma o seu envio.

No momento em que o atacante tem acesso à chave privada de quem assinou o arquivo, a adulteração no documento e/ou assinatura digital não é percebida.

Outro ponto positivo da assinatura digital é que as informações em um sistema de computador podem ser assinadas e serem testadas a sua autenticidade independente da segurança do sistema de armazenamento.

Sendo assim, podemos dizer que assinatura digital é um tipo de checksum criptográfico (checksum é um tipo de algoritmo cuja função é encontrar erros de conteúdo de dados em relação à origem e o destino) que tem por objetivo perceber ataques iniciados por fontes acidentais ou intencionais, que alterem o conteúdo de mensagens.

Requisitos de assinatura digital:

- A assinatura precisa ser um padrão de bits que depende da mensagem sendo assinada;
- A assinatura precisa usar alguma informação exclusiva do emissor, para impedir falsificação e negação;
- É preciso ser relativamente fácil produzir a assinatura digital;
- É preciso ser relativamente fácil reconhecer e verificar a assinatura digital;
- É preciso ser computacionalmente inviável falsificar uma assinatura digital, seja construindo uma nova mensagem para uma assinatura digital existente ou uma assinatura digital fraudulenta para de terminada mensagem;
- É preciso ser prático reter uma cópia da assinatura digital em termos de armazenamento.

Assinatura digital direta

O termo assinatura digital direto refere-se a um esquema de assinatura digital que envolve apenas as partes m comunicação (origem, destino). Considera-se que o destino conhece a chave pública da origem.

A confidencialidade pode ser fornecida pela encriptação da mensagem inteira mais a assinatura com uma chave secreta (encriptação simétrica). Observe que é importante realizar a função de assinatura primeiro, e depois uma função de confidencialidade externa. No caso de disputa, algum terceiro deverá ver a mensagem e sua assinatura. Se a assinatura for calculada sobre uma mensagem encriptada, então o terceiro também precisa acessar a chave de decriptação para ler a mensagem original. Contudo, se a assinatura for a operação interna, então o destinatário poderá armazenar a mensagem em texto claro e sua assinatura para uso posterior na solução da disputa.

A validade do esquema descrito depende da segurança da chave privada do emissor. Se um emissor mais arde quiser negar o envio de uma mensagem em particular, ele poderá reivindicar que a chave privada foi perdida ou roubada, e que alguém mais falsificou sua assinatura. Controles administrativos relacionados à segurança das chaves privadas podem ser empregados para afastar ou, pelo menos, enfraquecer essa tática, mas a ameaça ainda existe, pelo menos até certo ponto. Um exemplo é exigir que cada mensagem assinada inclua uma estampa de tempo (data e hora) e um relato imediato das chaves comprometidas a uma autoridade central.

Outra ameaça é de que alguma chave privada possa realmente ser roubada a partir de X no momento TO oponente pode, então, enviar uma mensagem assinada com a assinatura de X e estampada com uma hora antes ou igual a T.

11.1 Certificação digital

É um método digital que possibilita provar e/ou certificar que um arquivo digital foi realmente produzido por alguma entidade ou pessoa. Isso acontece já que o emitente da mensagem fornece uma chave pública para certificar a origem. Já o receptor se utiliza dessa chave pública digital que fica “anexada” ao arquivo eletrônico. Portanto, qualquer tentativa de alteração (proposital ou acidental) provoca sua invalidação.

Autoridade certificadora (CA ou AC): é uma entidade, privada ou pública, ligada a ICP-Brasil, cujas responsabilidades são: emitir, revogar, renovar, distribuir e gerenciar certificados digitais.

Há muitas autoridades certificadoras e cada uma delas possui seus certificados, métodos, formas e passos para certificação.

11.1 Segurança em Sistemas da Informação

Recentemente o advento da internet e seus serviços e crescimento dos sistemas vêm conquistando um grande e crescente volume de usuários. Com isso, muitas vulnerabilidades são reportadas e exploradas diariamente, o que exige das organizações e seus colaboradores, especialmente os ligados à área de SI, uma atenção mais que especial. Isso porque a segurança da informação atualmente é um quesito fundamental à manutenção e ao crescimento das empresas.

A internet é um potencial porta de entrada de ameaças para as organizações. Enquanto esse recurso não estiver pautado nas normas, políticas e mecanismos de segurança, a empresa estará em risco iminente.

A segurança da informação quando adequadamente aplicada tem o objetivo de blindar a informação, ativo fundamental de grande utilização nas empresas. Blindar o ambiente de informações adotando e aplicando procedimentos de segurança minimiza os riscos. Conforme já vimos, não é possível atingir a absoluta segurança. Além disso, os investimentos normalmente são altos e lamentavelmente muitos gestores não dão a devida atenção a essa necessidade.

Outro ponto a se observar são os ataques internos, promovidos pelos “insiders”, isto é, colaboradores da organização que por inocência ou malícia, exploram as vulnerabilidades e atacam as informações e sistemas.

Os modelos e mecanismos de segurança devem abranger todos os pontos possíveis que possam gerar vulnerabilidades, pois caso isso não ocorra, estas

poderão permitir as invasões e, consequentemente, perdas nos mais diversos níveis organizacionais.

Os sistemas de informação são responsáveis por preservar o funcionamento da organização, no que se refere ao controle e aplicação do ativo “conhecimento/informação”. Esses sistemas recebem a influência de diversos fatores, sejam eles físicos, humanos e tecnológicos. Sendo assim, é fundamental que recebam toda a proteção necessária em um ambiente controlado, com o objetivo de garantir a qualidade das informações.

Parece um contrassenso, mas em termos de vulnerabilidades, os armazenamentos manuais são mais seguros em relação aos eletrônicos. Isso porque os dados e informações tendem a ficar menos expostos.

As políticas em sistemas de segurança da informação devem levar em conta fatores como:

- Ações humanas;
- Invasão de terminais;
- Incêndios;
- Problema de fornecimento de energia elétrica;
- Falhas de hardware;
- Mudanças de programas;
- Problemas de telecomunicações;
- Falhas de software;
- Roubos de dados, de serviços e de equipamentos;
- Erros dos usuários.

A segurança da informação não deve ser tratada de uma única forma ou vista de apenas um ângulo; há vários processos, políticas e procedimentos com o objetivo de garantir que a informação esteja segura e ancorada nos pilares que representam esta informação.

A proteção da informação deve abranger as informações e conhecimentos organizacionais, bem como estar atenta às possíveis falhas e às quebras da

segurança evitando que o ativo “informações <-> conhecimentos” sejam danificados e/ou furtados.

Faz parte do conjunto de procedimentos e políticas, um plano de contingência bem preparado com implantação e execução garantida.

A segurança da informação deve ser tratada de maneira integrada, considerando todos os pontos de vista, sejam eles no âmbito pessoal (áreas técnicas, de gestão, operacional, etc.), como também em relação às necessidades e estratégias organizacionais, além das especificidades de todos os setores e colaboradores envolvidos.

As políticas ligadas à segurança da informação agregam diversos objetivos que elegem a SI como opção estratégica, pois traz consequências positivas à organização em todos os níveis. Algumas são:

- Implementar um sustentáculo de confiabilidade e proteção sobre o qual as diversas atividades ligadas à informação são elaboradas;
- Mostrar que a organização se preocupa com a conservação e integridade dos seus ativos em todos os níveis (informação, produtos, processos, etc.);
- Demonstrar que a empresa se dedica em cuidar dos objetivos dos clientes, colaboradores e parceiros,
- Deixar claro que os fornecedores e clientes representam o foco de quaisquer aplicações nesse ponto.

Nos últimos anos, as aplicações organizacionais ligadas aos sistemas e tecnologias da informação evoluíram de sistemas fechados e internos para sistemas abertos e distribuídos, nos quais as empresas possuem reduzidos controle e conhecimento, se comparado ao primeiro cenário. Isso alterou a forma de solução de problemas de segurança, já que o foco mudou da maneira puramente tecnológica para algo muito mais amplo.

Há fatores que influenciam diretamente na SI e não devem ser vistos de maneira independente e, sim, de uma forma holística, integrada e sempre alinhada às estratégias de negócios da organização.

São eles:

- **concentração:** Segundo este princípio, é necessário aprimorar a e ciência e a eficácia do gerenciamento dos critérios de proteção, diminuindo as duplicidades necessárias quando são utilizados preceitos iguais de proteção para resguardar repositórios distintos de informação estratégica;
- **consistência:** segundo esse princípio, os procedimentos de proteção em relação aos ativos com nível equivalente de importância também deverão se equivaler. Isto significa que a forma de proteção deverá ser homogênea em relação à importância dos ativos protegidos;
- **proteção em camadas:** este tipo de proteção sugere que os ativos e os respectivos métodos de proteção (tanto lógicos, quanto físicos) sejam organizados de maneira concêntrica, sendo que os mais importantes estrategicamente fiquem no centro e os menos na periferia;
- **relação custo/benefício:** essa relação indica a necessidade de assegurar que os gastos ligados à implementação de políticas de segurança e o retorno desse investimento (ROI) seja traduzido em proteção e prevenção;
- **redundância:** esse fator reforça a necessidade de utilizar mais de uma maneira de proteção para o mesmo tópico com o objetivo de preservar um ativo. Isso é fundamental, pois garante que, em caso de perda do recurso principal de segurança, um recurso secundário atue aumentando assim a segurança.

Preservar a integridade, confidencialidade e disponibilidade da informação contida em sistemas que tratam desse ativo exige políticas de segurança, que muitas vezes asseguram o não repúdio e a autenticidade.

A prevenção é o conjunto das medidas que visa reduzir a probabilidade de concretização das ameaças existentes. O efeito dessas medidas extingue-se quando uma ameaça se transforma em um incidente.

A proteção refere-se às atitudes que visam munir os sistemas de informação com algumas capacidades como inspeção, detecção, reação e reflexo,

proporcionando a diminuição bem como a contenção das consequências das ameaças quando elas aconteçam.

Principais papéis na segurança da informação:

- **direção/administração:** esse setor, assim como os colaboradores por ela designados, é e/ou representa os donos do conhecimento e da informação utilizados pela organização na comercialização e produção de seus bens, produtos e ser viços, além do relacionamento com os clientes e parceiros;
- **usuários:** são todos os que utilizam os sistemas de informação, independentemente dos níveis de acesso que tenham. Suas habilidades e conhecimentos técnicos variam de acordo, basicamente, com dois fatores: a faixa etária e o tipo de atividade desempenhada;
- **pessoal técnico:** o software, hardware e outros recursos e insumos ligados à TI (redes, dispositivos de redes, etc.) precisam de gerenciamento contínuo. Essas tarefas de gestão ficam a cargo de colaboradores (contratados ou terceirizados). Normalmente, independentemente da sua função, o pessoal da área de TI possui conhecimentos mais profundos e específicos, de acordo com sua atuação na área (redes, manutenção, desenvolvimento, suporte, etc.) se comparado aos usuários leigos. Um treinamento insuficiente ou inadequado pode abrir brechas para uma possível ameaça colocando em risco os ativos de informação e conhecimento;
- **parceiros:** são as entidades externas que cooperam de alguma forma com os negócios da organização, nos mais diversos níveis. Esses personagens podem participar, ou até gerenciar as políticas de SI na empresa.

Os modelos de segurança da informação devem possuir os seguintes princípios:

- **envolvimento:** fazer com que a organização tenha uma visão holística da segurança da informação, já que a implementação de algumas soluções exige que o panorama seja do contexto geral do negócio;
- **exposição:** deixar claro que nenhum ponto relativo à informação está livre de ataques, fato que estimula à atenção constante;
- **emergência:** integrar todos os componentes organizacionais a SI.

- **diversidade:** diversificar as estratégias de prevenção, proteção e recuperação. É o famoso “Plano B”;
- **contexto:** propor soluções tecnológicas fundamentadas no ambiente organizacional e na forma correta de utilização dos sistemas.

A internet oferece um paradoxo, pois tenta estabelecer o equilíbrio entre a fácil acessibilidade e a restrição de acesso, ou seja, o acesso deve ser fácil e rápido aos usuários autorizados e o mesmo acesso deve ser seguro e robusto para os usuários indevidos. É fundamental compreender, que o triunfo das organizações está ligado diretamente à segurança e ao controle das informações. Isso porque, conforme vimos, as falhas de segurança estão em constante crescimento, aumentando também os riscos das empresas, no que se refere à perda e/ou furto das informações. As empresas necessitam de controles para detecção e prevenção de falhas de segurança. Porém, é fundamental que isso seja efetuado de maneira organizada e assertiva controlando as responsabilidades por toda a organização.

A utilização de sistemas de informação exige dos gestores uma prévia garantia de estabilidade, segurança e confiabilidade. Dessa forma, todas as providências necessárias para garantir esses pontos, devem ser tomadas. O objetivo é evitar (ou minimizar) que fatores internos e externos (falhas de comunicação, acessos não autorizados, erros de hardware e de software, treinamentos indevidos, vírus, sinistros naturais) provoquem um mau funcionamento ou interrupção dos serviços que dependam da informação. Com esse objetivo, são muitos os desafios que os gestores devem encarar. Podemos citar alguns:

- elaborar programas e sistemas com níveis equilibrados de controle, nem em excesso e nem em falta, pois ambos são prejudiciais. O excesso do controle desencoraja a utilização dos usuários, enquanto a falta gera vulnerabilidades;
- utilizar as melhores práticas para o projeto e desenvolvimento dos sistemas;
- tornar os sistemas (software / hardware / pessoas) mais resistente a falhas;
- criar políticas e estratégias para continuidade do negócio;
- dedicar atenção à segurança da rede, interna e externa, pois é uma porta, em potencial, que se não estiver segura, permitirá o acesso não autorizado.

É importante que o gestor defina regras para realizar reuniões com o objetivo de avaliar e classificar as possíveis ameaças e impactos. Algumas dessas regras podem incluir:

- a participação de todos os stakeholders, item fundamental;
- foco no assunto, adequando-o ao tempo;
- coleta ampla de ideias, em que todas devem ser igualmente válidas;
- os assuntos dever ser debatidos o mínimo possível;
- a objetividade deve ser um pré-requisito.

Outro ponto de extrema importância é a forma como a organização deve reagir no caso de um desastre, pois este pode gerar consequências, às vezes incalculáveis. A resiliência organizacional estabelece a capacidade de sobrevivência, além de demonstrar a quão preparada está a organização e a atenção que foi dedicada ao caso.

A preparação e implementação de um plano de reação aos sinistros, com todas as suas variáveis, não é uma empreitada simples e necessita do empenho de todos na organização. Isso porque, a criação dessas medidas de segurança poderá garantir a continuidade da organização, caso o pior aconteça.

As características do programa de segurança da informação são únicas, em função da sua abrangência e importância. Exige análises profundas em todos os pontos e sob todos os prismas. Tratar de um programa desses sem a devida atenção poderá gerar desvios extremamente prejudiciais para a organização. Portanto, todos os participantes do processo devem estar alinhados aos conhecimentos gerados e às estratégias a serem utilizadas na preparação e implementação desse programa de segurança.

Dois outros fatores de sucesso são: a escolha adequada da equipe e a comunicação do programa a toda empresa. Dessa forma, é possível garantir que todos os objetivos fiquem alinhados a toda parte interessada (stakeholders).

O controle eficiente de todas as atividades durante todo o programa proporcionará a proatividade na solução das dificuldades e problemas, bem como avaliar a eficiência e eficácia das metodologias adotadas e implementadas.

Em muitos casos, lamentavelmente, o valor dos sistemas de SI (Sistemas de Informação), só são percebidos quando ocorre um problema, pois as perdas decorrentes de sua falta podem variar entre o “desagradável” e o “desastroso”.

Atualmente, muitos sistemas e aplicações envolvendo sistemas de informação, são utilizados por toda a sociedade moderna. Alguns exemplos são os sistemas de companhias aéreas, sistemas bancários, comércio eletrônico, etc. Sendo assim, é fácil perceber que esses sistemas devem possuir alta disponibilidade, desempenho e estabilidade, pois problemas implicam em prejuízos. O principal objetivo da segurança em Sistemas de Informação se relaciona com a proteção e controle do ambiente computacional, garantindo a da segurança de informação.

12. MODELOS E MECANISMOS DE SEGURANÇA DOS SISTEMAS DE INFORMAÇÃO

Um Sistema de Informação é um agrupamento de elementos que se inter-relacionam, com o objetivo de captar, processar, armazenar e disponibilizar dados e informações de modo que possam dar apoio à gestão e ao processo de tomada de decisões, além de facilitar o controle organizacional. Esses sistemas podem conter informações sobre locais, pessoas, procedimentos e demais informações importantes para a organização ou seu ambiente (interno e/ou externo).

Tais sistemas devem abranger todos os elementos e fatores úteis à direção dos negócios. Esses elementos normalmente contemplam das atividades corriqueiras até o conhecimento que foi produzido pela empresa.

Eles devem ser projetados a se ajustarem às organizações e às suas estratégias, gerando as informações e conhecimentos necessários e importantes ao

andamento de suas atividades. Portanto, a empresa deve estar atenta às interações geradas pelo Sistema de Informação, ajustando a maneira de atuação, de acordo com fatores como: influência do mercado, estratégias do negócio, mudanças de legislação, dentre outros.

A importância da informação e do conhecimento é responsável pelo empenho na criação e manutenção dos Sistemas de Informação com o objetivo de garantir sua proteção, segurança e a consequente continuidade dos negócios da organização.

12.1 Metodologia para garantir a segurança nos sistemas de informação

Uma metodologia básica e inicial compreende algumas etapas:

- avaliar os riscos e possíveis impactos que podem expor os sistemas de informação;
- definir, com base nas estratégias e possibilidades da empresa, os níveis de segurança desejáveis e essenciais aos sistemas;
- efetuar a devida comparação entre os níveis de segurança desejados e atingidos;
- avaliar todas as técnicas disponíveis e possíveis, que tenham por objetivo a segurança dos sistemas;
- desenvolver, implementar e implantar as técnicas escolhidas com base nos itens anteriores;
- testar essas técnicas de modo a garantir a sua eficiência e eficácia.

Sendo assim, os principais objetivos da segurança nos sistemas de Informação são:

- diminuir probabilidade de que incidentes de segurança ocorram;
- reduzir os possíveis danos causados pelos incidentes;
- garantir a recuperação organizacional, caso aconteçam falhas de segurança.

Em resumo, a segurança da informação começa com o estabelecimento de uma política organizacional de segurança ampla e, em seguida, pela análise e gestão

dos riscos inerentes, incluindo controles de acesso lógico e físico aos sistemas e recursos de informação, lembrando, obviamente dos treinamentos e da conscientização dos colaboradores. Contudo, não pode deixar de existir planos de contingência, recuperação de sinistros e continuidade do negócio.

A presença e o devido suportem da direção são fundamentais para o sucesso da política e dos sistemas de segurança de informação. Esse suporte não se baseia apenas no nível financeiro, mas principalmente na elevação da segurança de informação a um patamar de alta prioridade. As atitudes para garantir a SI devem ser planejadas e implantadas nas etapas incipientes do desenvolvimento do sistema, dessa forma, todos os mecanismos de proteção estarão implantados, juntamente com os sistemas reduzindo o risco e aumentando a eficiência.

12.2 Mecanismos de segurança da informação

Estes mecanismos abrangem controles como:

- **físico:** evita o acesso indevido às instalações e ao ambiente computacional;
- **lógico:** controla o acesso aos sistemas, por meio de autenticações, além das permissões por níveis de acesso;
- **humano:** nesse caso, os treinamentos de colaboradores e parceiros são fundamentais, pois aumentam a eficiência evitando erros de operação, além de reduzir o risco por ataques por meio da engenharia social.

Os softwares (básicos e aplicativos), bancos de dados, sistema operacional, arquivos de senha e histórico de utilização por constituírem o maior foco dos ataques, também representam o principal objeto de proteção.

Há várias formas em nível de software e hardware que são utilizados, na preservação da Segurança de Informação. Conforme já vimos, assinatura digital, certificados digitais, criptografia, segurança física, planos de gestão de riscos e da continuidade de negócios (PCN), controle de invasões, softwares e políticas contra

intrusos virtuais (antivírus, anti-spyware) são alguns dos mecanismos para a segurança da informação.

Eles podem ser agrupados em três grupos:

- Segurança na comunicação: visa proteger os dados e as informações no momento em que estão sendo trocadas ou compartilhadas por meio de uma rede local (LAN), intranet ou mesmo internet. Vimos em outras unidades, algumas das formas de implementar esse tipo de segurança: criptografia (e suas diversas formas), certificados digitais e assinaturas digitais;
- Controles de acesso lógico: esses controles são elaborados usando conjuntos de hardware e software, adequadamente configurados, de modo que os usuários não autorizados não consigam usar os recursos computacionais. Além disso, no caso de serem usuários, eles possuem níveis de acesso de acordo com a função. Dessa forma, só veem e acessam o que lhes for autorizado;
- Controles de acesso físico: visa proteger a estrutura física na qual a parte lógica está instalada. Isso é feito de algumas formas: autorização formal de acesso às dependências da empresa, nos locais onde se encontram os equipamentos (servidores, switch, equipamentos de rede) que devem permanecer trancados e protegidos. Além disso, deve-se manter uso constante de crachás ou credenciais nessas áreas.

Lamentavelmente, não existem mecanismos com 100% de eficácia na proteção dos sistemas de informação. Por isso, todos esses possíveis mecanismos devem atuar em conjunto.

Sendo assim, é muito importante a existência de planos que minimizem o impacto no caso de sinistros. São eles:

- **Plano de recuperação de desastres:** nesse ponto, após a ocorrência de um sinistro, os recursos de TI que foram prejudicados são substituídos por outros adequadamente preparados, agilizando a restauração total ou a um nível aceitável. Esse plano recomenda que uma organização mantenha seu funcionamento mesmo após a ocorrência de problemas. Um plano de recuperação de desastres visa solucionar dois problemas: primeiro, a forma de

restaurar as operações após a ocorrência de um incidente e o segundo, como se comportar durante a recuperação de um primeiro sinistro, se um outro ocorrer. Isso deixa claro que o plano de recuperação de desastres também deve levar em conta as prioridades e as respectivas resoluções dos conflitos;

- **Plano de contingência:** o objetivo desse plano é manter o funcionamento dos sistemas mesmo que tenha havido um sinistro. Ele é composto de 4 fases:

➢ Análise preliminar: aqui são realizados os estudos iniciais avaliando e detectando recursos e funções críticos, além de deixar claro para a gestão organizacional e para os colaboradores, a necessidade de a empresa possuir um plano de contingência;

➢ Análise de impacto: nessa fase, são avaliados os impactos sobre a organização no caso de um sinistro. Essa análise abrange a avaliação de tempo de parada e o custo correspondente de cada atividade envolvida;

➢ Análise das opções para recuperação: nesse caso, são produzidos estudos sobre o que é possível fazer para recuperar os sistemas e ser viços e/ou mantê-los funcionando;

➢ Criação do plano de contingência: aqui o plano é definido e detalhado e os recursos diversos são estabelecidos. Essa fase considera algumas etapas para a recuperação de um sinistro, são elas: detectar e entender o problema; restringir os prejuízos (financeiros ou não); conter e/ou solucionar o problema; identificar as perdas; restabelecer o funcionamento dos sistemas e, por fim, extinguir os motivos de modo a evitar nova ocorrência do sinistro.

Outro ponto fundamental é disseminar a cultura da segurança da informação, pois como visto, ela é composta de vários pilares e vista de várias formas. Sendo assim, é importante que exista um plano para conscientizar toda a organização para que todos os envolvidos, em todos os níveis (operação, desenvolvimento, manutenção, redes, etc.) recebam os devidos treinamentos de modo que possam participar ativamente de todos os processos associados à Segurança de Informação.

Os treinamentos devem ser constantes, com o objetivo de manter todo o quadro de colaboradores em sintonia entre si e com as normas, treinamentos e conceitos, além do comprometimento com os procedimentos para garantir a Segurança de Informação.

Toda a equipe do projeto deve estar preparada para transmitir credibilidade ao longo da implementação da Segurança de Informação.

Todas as diretrizes e normas devem ser divulgadas de forma intensiva por toda a empresa. É necessário que essas normas e diretrizes descrevam o que será protegido, bem como atitudes que serão tomadas no caso de problemas de segurança.

É fundamental salientar que os problemas que interferem em um ou mais pilares de SI podem provocar consequências, como a redução e/ou perda negócios e de confiabilidade em relação aos clientes e parceiros.

13. REFERÊNCIAS:

FONTES, Edison. Políticas e normas para Segurança da Informação Cism, Cisa, Crisc. Rio de Janeiro: Brasport, 2014.

INSTITUTO NACIONAL DE TECNOLOGIA DA INFORMAÇÃO. Disponível: Institucional. Disponível em: www.iti.gov.br/icp-brasil.

LOBO DE FARIA, Rodrigo Gomes. Fundamentos de segurança da informação. Belo Horizonte. 2016.

SÊMOLA, Marcos. Gestão da Segurança da Informação: uma visão executiva. Rio de Janeiro. Módulo, 2013.

STALLINGS, William. Criptografia e segurança de princípios e práticas. 6º ed. Pearson.